



Review

Anti-phishing: A comprehensive perspective

Gaurav Varshney^a, Rahul Kumawat^b, Vijay Varadharajan^c, Uday Tupakula^c, Chandranshu Gupta^{a,*}

^a Indian Institute of Technology Jammu, India

^b Amazon Development Center, India

^c The University of Newcastle, Australia

ARTICLE INFO

Keywords:

Anti-phishing

Phishing

Deception

Cyber laws

Social and cognitive factors

ABSTRACT

Phishing is a form of deception technique that attackers often use to acquire sensitive information related to individuals and organizations fraudulently. Although Phishing attacks have been known for more than two decades, and there is ongoing research for developing effective techniques against these attacks, the increasing trend of attacks confirms the lack of robust solutions and techniques against these attacks. According to Trend Micro, over 90 percent of all Cybersecurity attacks begin with spear Phishing emails and hence there is a need for comprehensive research in the area of anti-Phishing to improve the overall Cybersecurity landscape. This paper, therefore, performs a comprehensive study and analysis of past research work in anti-Phishing. The survey also tries to study various relationships such as those between the Phishers and the motives behind Phishing and explores/assesses various tactics that are employed for launching Phishing attacks. Highlighting the role of social and cognitive factors in the success of a Phishing attack which was not focused on in earlier reviews, is one of the major contributions of this work. The paper also provides a detailed understanding of the types of Phishers and the type of Phishing performed by them with a comprehensive classification of anti-Phishing detection/prevention/awareness solutions through a systematic literature review. The contributions of leading organizations and their active role through various anti-Phishing products are also discussed in this paper to bring light to the research and development happening in the industry with respect to anti-Phishing. Finally, the cyber laws to handle Phishing attacks in various countries have been presented for readers' interest. We believe this survey brings new knowledge and a comprehensive perspective to its readers from academia and industry to explore new horizons for research activities in anti-Phishing.

1. Introduction

Phishing refers to a set of cyberattacks where deception and disguising techniques are employed by an attacker to gain access to the victim's sensitive information on the Internet. Phishing is historical, and its first known occurrence was recorded in 1995 when the hackers posed themselves as American Online (AOL) staff members and tricked AOL users into revealing their usernames and passwords [AOHell] (Al-Abdan, 2020). Hackers at that time used instant messaging services as a platform for tricking AOL users into entering their usernames & passwords on instant messages. One aspect differentiating Phishing from other cyberattacks is the inclusion of deception techniques in its planning, execution, and eventual success. Phishing is a four-step process that includes the following:

1. Gaining Trust: In this step, the attacker tries to gain the victim's trust so that he/she performs the desired actions the attacker

needs. Actions can be, clicking links, replying to an email, etc. Trust is gained via spoofing websites, email addresses, apps, etc.

2. Redirection: This is an intermediate step and may or may not exist in all Phishing attacks. In the case of a spoofed email, the redirection may cause the user to reach a Phishing site via a link. Most of the time, actions after gaining trust result in redirection. Users then provide their credential information on the redirected sites/channels.
3. Gaining Data: In this step, the actual launch of the attack happens. The attacker receives the required information over redirected forms/websites or as a reply over spoofed emails by the victim.
4. Execution: In this step, the attacker executes the required identity fraud or financial fraud using the identity or credential information obtained in Step 3.

* Corresponding author.

E-mail addresses: gaurav.varshney@iitjammu.ac.in (G. Varshney), rahul-kumawat@hotmail.com (R. Kumawat), vijay.varadharajan@newcastle.edu.au (V. Varadharajan), uday.tupakula@newcastle.edu.au (U. Tupakula), 2021RCS1022@iitjammu.ac.in (C. Gupta).

<https://doi.org/10.1016/j.eswa.2023.122199>

Received 1 November 2022; Received in revised form 9 June 2023; Accepted 15 October 2023

Available online 30 October 2023

0957-4174/© 2023 Elsevier Ltd. All rights reserved.

Over the last two decades, Phishing attacks have significantly affected organizations around the globe (APWG, 2022). As the solutions to block Phishing attacks have advanced over time, the attackers have also learned advanced ways of launching new types of Phishing attacks. Despite several years of research by Industry and Academia, the threat of Phishing attacks still persists today.

In our view, Phishing attacks can be addressed by a more systematic approach that not only considers advancements in technologies to detect or prevent them but also focuses on important non-technical factors that play a crucial role in launching them. To our understanding, the prior work has not focused on some of the aspects of the problem given below:

- Social and cognitive aspects of Phishing are often ignored/not focused on.
- Less focus on anti-Phishing awareness and training.
- Less exploration of the relationship between Phishers and motives behind Phishing.
- Discussions on anti-Phishing laws and their role in curbing Phishing attacks are not studied much.
- The role of anti-Phishing organizations and anti-Phishing awareness and training programs in countering Phishing attacks are often ignored.
- A comprehensive review that studies Phishing attacks in detail across various perspectives/horizons and analyzes the anti-Phishing solutions/approaches and the role of various stakeholders in curbing Phishing attacks is missing.

All the aspects mentioned above are critical requirements for developing robust solutions for anti-Phishing. In this paper, we aim to address these gaps by performing a comprehensive survey that brings light to the technical and non-technical aspects related to Phishing attacks. We also perform a critical analysis of existing solutions and efforts by various anti-Phishing organizations in dealing with the problem.

The specific contributions of our work are as follows:

1. A systematic study of major Phishing attacks in the past to gain deeper insights into the real-world impact of Phishing attacks.
2. Analyzing various tricks/ techniques used by attackers in launching a Phishing attack.
3. Studying and discovering the non-technical factors that play a major role in a successful Phishing attack.
4. Detailed classification of various Phishing attacks (including modern techniques) and the study of motives behind these attacks.
5. Detailed classification and analysis of various Phishing detection and prevention schemes with suggestions on how such schemes can be improved.
6. Survey of the role of anti-Phishing organizations and their products.
7. Study of the laws across various countries for handling Phishing crimes.

The approach that we have used in carrying out this survey is as follows: Firstly, we have studied and analyzed the situation of Phishing attacks on the web. For the same, we referred to the Anti Phishing Working Group [APWG], which is an international consortium that tries to put an end to scams done via Phishing and associated events. APWG has been used to obtain statistics on Phishing emails and Phishing websites for the past seven years. The growth in Phishing is then analyzed and presented in the survey. We then followed a systematic methodology to collect the appropriate research papers on Phishing. We searched different databases such as IEEE Xplore, Google Scholar, DBLP, and ACM Digital Library independently with keywords such as “Phishing”, “major Phishing attacks”, “Phishing attacks”, “Phishing survey”, “anti-Phishing”, “Phishing countermeasures”, “Phishing

solutions”, “Phishing mitigation” etc. For this paper, we have mainly searched the different databases mentioned above to look for major Phishing attacks and solutions since 2009 using the keywords mentioned above. Moreover, to search specifically for Social and cognitive factors involved in Phishing, we used the queries “Phishing factors”, “Phishing human”, “Phishing human factors”, and “Phishing social factors”. Also, to search for anti-Phishing training and awareness we used the keywords “Phishing awareness and “Phishing training”. Finally, we used the query “Phishing laws in x”, where x = Name of the country, on the internet, as this query on the above-mentioned databases did not yield any significant results. For this paper, we have mainly considered papers having conference/journal CORE ratings greater than C.

We have gathered the information on Phishing attacks and their countermeasures as available from these Internet sources and tried to provide an insight to the reader in terms of how the attacks were launched, what damage they caused, what tricks and technologies were implemented, and how redirection or deception was carried out. We understood the motives behind Phishing and types of Phishers from prior research work and online sources and tried to add a level of classification and knowledge from our understanding of the subject.

We have then looked into the domain of Phishing from an attacker’s perspective and implemented and tested some of the major Phishing tricks and techniques which have been discussed in the past by various researchers. The implementations were done in a suitable test environment to see the applicability of such tricks and techniques at the present time. This also helped us in categorizing the Phishing attacks based on the redirection techniques and on the deception mechanisms used to obtain the user credentials.

The existing prevention schemes were analyzed for security, while the Phishing detection schemes were classified and analyzed in terms of the technology used for Phishing detection, the accuracy of detection, resource utilization, and dependencies.

After a thorough understanding of the subject, we have focused on the social and cognitive factors, which are, however, non-technical but had an impact on the success of a Phishing attack. Most of this discussion comes from prior research work in this area and psychological understanding of the subject available from Internet sources. We have a major contribution in proposing the insights that we have received from our understanding of the subject while working on it for the last ten years.

Then we focused on the popular anti-Phishing organizations that are working in this domain and their current strategies for handling Phishing attacks. The organizations were selected based on the popularity of their anti-Phishing product and services available in the market. This is done via searching over the web and references available from prior research work and information made available by third parties working on Anti-Phishing. The APWG site has references to organizations and was considered while selecting the organizations (APWG, 2022).

We finally included an understanding of various cyber laws that are aimed to prosecute individuals in crimes related to Phishing attacks.

We noticed that there are a few latest comprehensive surveys available on anti-Phishing and on Phishing attacks and their classification. Moreover, the non-technical concepts to control Phishing are very rarely mentioned in any survey. Therefore, though there are many surveys in the area of Phishing, we believe that there has been no literature survey that provides an understanding of Phishing with such comprehension. In Table 1, we have tried to demonstrate the focus areas of some of the recent detailed surveys and compared them with the focus area of this survey to help the reader understand the specific additions one can expect in this work.

The paper is organized as follows: Section 2 presents some recent surveys of Phishing attacks with their impact, an analysis of specific Phishing incidents, the Relationship between Phishers and Motives of Phishing, Phishing classification based on individuals targeted, and the relation between Phishers and type of Phishing. Section 3 presents a detailed discussion of the Phishing attack tactics such as different

Table 1
Recent phishing surveys and focus areas.

Focus Areas, Papers	Alabdan (2020)	Tang and Mahmoud (2021)	Khonji et al. (2013)	Das et al. (2020)	Dou et al. (2017)	Silva et al. (2020)	Basit et al. (2021)	Desolda et al. (2021)	Our work
Attack Tactics	•	×	◦	◦	◦	•	×	×	•
Social, Cognitive	◦	×	×	×	×	×	×	•	•
Types of Phisher	×	×	×	×	×	×	×	×	•
Phishing Motives	×	×	◦	×	◦	◦	×	×	•
Anti Phishing	D, P	D	D	D, P	D	D	D	P	D, P
Evaluation Metrics	×	•	•	•	•	×	◦	×	×
Awareness Solutions	◦	×	×	×	×	×	×	•	◦
Commercial Solutions	×	×	×	×	×	×	×	×	•
Anti Phishing Laws	◦	×	×	×	×	×	×	×	•

Note: D- Detection, P- Prevention, ×- Not Focused, ◦-Less Focused, •- Focused

Table 2
Terminologies used.

Terms used	Definition
Victim	An individual victim of a Phishing attack
Victim organization	An organization victimized via a Phishing attack
Target	An individual/group of people targeted by a Phisher
Target organization	An organization targeted by a Phisher
Losses	Loss incurred by the organization or their customers

deception techniques used by the attackers to divert the victims to the attackers' websites and then discusses different techniques used by the attackers for the acquisition of the user credentials. Section 4 presents a detailed discussion of non-technical aspects of Phishing. All the social and cognitive factors behind Phishing are discussed in detail in this section. Section 5 talks about anti-Phishing detection and prevention schemes, and Section 6 presents different organizations that are working on anti-Phishing solutions. Section 7 considers Cyber laws on Phishing in different countries, and Section 8 concludes the paper.

2. Attacks overview

In this Section, we present an overview of the Phishing problem on the Internet and an analysis of some of the major Phishing attacks. Then we present a detailed discussion of different types of attackers that are involved in the generation of Phishing attacks and consider the motivations of attackers for performing the attacks. We also present the classification of attacks based on the individuals targeted by the attackers. In Table 2

2.1. Survey of the attacks

According to Avanan's Global Phish Report 2019 (AVANAN, 2019), Out of every 99 emails, one email leads to a Phishing scam. Also, in every 25 brand emails, at least one leads to a Phishing scam.

The APWG (APWG, 2022) tracks the number of unique Phishing websites. Table 3 gives the data of a number of unique Phishing websites detected from the year 2015 till 2021 quarterly. As we can see in Table 3 in Q1 of 2015, 136 347 Phishing websites were detected, which has increased to 888 585 in Q4 of 2021. Although the year 2017 saw the minimum number of Phishing websites detected throughout the year, the total number was still 662,795 which is still very high. In the year 2019, it was more than half of 2017 in just two quarters and since the Q3 of 2020, the numbers have increased significantly when compared to previous year results. In the year 2021, the numbers were the highest. Q3 and Q4 of 2021 had more Phishing websites detected than it was in the entire year of 2017. Also, a study by ENISA (<https://www.enisa.europa.eu/>) has identified that COVID-19 was one of the dominant lures for deception attacks during 2021.

Despite the fact that there were less Phishing websites discovered from 2017–2019, the two years 2020 and 2021 have revealed a different picture. It is not shocking that in 2020, when the world seemed

Table 3
Number of Unique Phishing Websites Detected.

	Q1	Q2	Q3	Q4	Total
2015	136 347	253 007	241 140	158 574	789 068
2016	289 371	466 065	365 024	277 693	1 398 353
2017	144 721	146 375	190 942	180 757	662 795
2018	263 538	233 040	151 014	138 328	785 920
2019	180 768	182 465	266 387	162 155	791 775
2020	165 722	146 994	571 764	637 302	1 521 782
2021	611 877	616 939	730 372	888 585	2 847 773

to stop because of the start of the continuing worldwide pandemic, unscrupulous actors seized the opportunity. As a result of being cooped up indoors, people all across the world spent more time than usual staring at their phones, tablets, and laptops. Many previously infrequent online shoppers have become regulars, making it easy prey for hackers who have increased the number of spoof websites to take advantage of the trend. Attempting to capitalize on people's fear and curiosity, a number of parody sites covering the Covid-19 incident sprung up on the internet. From April 2020 onwards, there was a consistent rise in the number of Phishing sites discovered, with a 92% year-over-year increase reported in 2020 compared to 2019. A subsequent increase of nearly 30% in 2021 indicates a persistent rise in the number of spoof websites seeking to trick consumers into disclosing sensitive information. This trend is likely to continue, though perhaps not at the same rapid pace as 2020.

Table 4 gives the data of unique Phishing emails subjects reported from 2015–2021. In 2015, the maximum number of unique Phishing email subjects reports were received. In Q1 of 2016, the highest number of email campaigns were received, which were almost 50% more than in Q4 of 2015. Again in the first quarter of 2017, there was an increase of almost 108,000 from Q4 of 2016, and then a zig-zag in Q2, Q3, and Q4 of 2017. In 2018 after getting a hike in the first quarter it remained almost constant throughout the year with a slight decrease in the last quarter of 2018. From Q1 of 2019 till Q2 of 2020, we saw a constant number of reports received which were lower when compared to previous years' quarterly reports. Then in Q3 and Q4 of 2020, there was an increase in the number of reports received. Q2 of 2021 saw the lowest number of reports received in a particular quarter and the year 2021 saw the minimum number of reports in a particular year since 2015. Recently (APWG, 2022) in Q3 of 2022 recorded a total of 1,270,883 Phishing attacks, setting a new all-time high and making it the most severe quarter for Phishing ever recorded by the APWG.

The APWG Phishing Trends Report dispels the common belief that as there is increase in unique distinct Phishing websites, there will also be more unique Phishing email subjects. More than a million email Phishing targets were found in 2018 which reduced by 57% in 2019. With an unavoidable increase in 2020 due to lockdown, the numbers again decreased by more than 50% in the year 2021. While the total quantity of emails is decreasing again, this may be due in part to increasingly targeted and sophisticated Phishing efforts.

Table 4
No. of Unique Phishing Email Subjects.

	Q1	Q2	Q3	Q4	Total
2015	287 411	417 472	395 015	380 548	1 480 446
2016	557 964	315 524	229 251	211 032	1 313 771
2017	318 940	273 395	296 208	233 613	1 122 156
2018	262 704	264 483	270 557	239 910	1 037 654
2019	112 393	112 163	118 260	132 553	475 369
2020	139 685	127 687	367 287	396 688	1 031 347
2021	325 080	30 308	86 333	42 748	484 469

Therefore, if their Phishing tactics are successful with less work, they may not need hundreds of distinct email subjects. This notion is supported by CoFense's (Cofense, 2020) research of anticipated Phishing campaigns for 2020, which predicts that fraudsters will continue to target well-known services such as Google Drive, Amazon, SharePoint, and WeTransfer in an attempt to deceive unwary clients. In 2019, Symantec (2019) predicted that fraudsters would change to highly targeted campaigns rather than a spray-and-pray tactic, leading to dropping rate of Phishing email subjects. Since the increase in 2020 due to pandemic, there has been a drastic drop, suggesting that the Phishers have determined which email topics are most profitable and are concentrating on those.

From Tables 3 and 4, there seem to be more unique Phishing email subjects reported compared to unique Phishing websites detected during the years 2015, 2017, and 2018. We have also noticed a decreasing trend in the number of reported unique Phishing email subjects compared to the unique Phishing websites detected during 2016, 2019, 2020, and 2021. Based on our research, we have identified that adopting security techniques such as: Sender Policy Framework (SPF) and Domain-based Message Authentication, Reporting, and Conformance (DMARC) may be contributing to the decreasing trend in unique Phishing email subjects. In Section 3, we present a detailed discussion of different forms of Phishing tactics used by the attackers, including SMS, DNS hijacking, and Clickjacking. There are security extensions for SMTP, including SPF, DKIM, and DMARC. With SPF, Sender Policy Framework, records can be set in the DNS specifying a list of IP addresses allowed to send emails for a given domain. Similarly, the DMARC extension provides policies that allow email servers to determine which actions to take when the SPF or DKIM policies fail. The adoption rate of SPF till 2019 was about 50.7%, showing a significant increase of 25% from 2015. The adoption rate has now even increased to 61.7% in the year 2022. Although the adoption rate of DMARC is just 11.5% it has increased ten times between 2015–2019 (Tatang et al., 2021). Moreover, for the year 2021, the total number of valid DMARC policies in use has increased significantly by 84%, nearly doubling the increase in percentage to that of the year 2020 (DMARC, 2021).

The Table 5 presents the data collected from Kaspersky's spam and Phishing reports (Kaspersky, 2022). The top 5 industry categories in the last 7 years facing Phishing attacks were Global Internet Portals(GIP), Banks, E-Payment, Online Stores and Social Networking, Telecom and Internet Service Providers(ISP), Instant Messaging(IMS), Government Organizations and Taxes, Online Games and Other were the choices of Phishing attacks. The other category includes IT vendors, Delivery Companies, Mass Media, Airlines, etc. In 2015 the most targeted organization category was Global Internet Portals which accumulated 31.87% of attacks, then the banks were the second most targeted industry. Also, if we combine all financial industries(Banks, E-Payment, and Online Stores), it has a share of 34.33% of all attacks. In other words, every 3rd Phishing attack targeted a financial institution.

In 2016 Banks themselves were the most targeted industry, the second most targeted industry was Global Internet Portals, and E-Payment, E-com, and Social Networking industries were targeted almost equally.

Also, the combined financial industry was targeted 47.48% times in all Phishing attacks.

In 2017, the top two most targeted industries were Banks and E-Payment, with 27% and 15.87% attacks. In 2018, the top two most targeted industries were again Global Internet Portal and Banking industries. Also, 2018 saw a change in attackers' choices making the Government and Taxes the top 5 targeted industries for the first time. The attacks on Government and Taxes increased from 1.31% in the previous year to 8.95% in 2018, which is a 585% increase in attacks. In 2019, the top two targeted industries were banking and global internet portals, but in 2020, online stores became the most targeted industry, whereas GIP remained second. Similarly, in 2021, online stores were the top targeted industry, and Global Internet Portal was the second most targeted industry. In our view, as most purchases were made online during COVID-19, the attackers have increasingly targeted online stores.

According to Kaspersky's (Kaspersky, 2019) and Vadesecure's (Vade, 2023) spam and Phishing reports top 3 organizations targeted during the years 2017–2022 are shown in Table 6. This table depicts organizations whose names are mostly used by Phishers to target individuals/organizations. As can be seen from the table, both Microsoft and Facebook have been regular entries in the Top 3. This is because by impersonating these brands, the Phishers can easily target mass users, and hence the probability of a successful attack is high.

As we can see from the above discussion that the trends of Phishing are changing with time from industry to industry. The trend is shifting more towards financial institutions, global internet portals also, including government organizations, and taxes. Also, the attackers have increasingly targeted attacks on online stores during 2020–2021, where most activities were performed online due to the COVID-19 outbreak.

Table 7 contains the data of the top 10 countries by percentage of attacked users during the years 2017–2022. From Table 7, it is clear that Brazil topped the chart almost every year, but in 2022, its position dropped to 8 (Kaspersky, 2022). Brazil introduced Law No. 14.155, which punishes theft committed through fraud when using an electronic or computer device, whether it is connected to the internet or not. This new Law is discussed more in Section 7.

Moreover, Vietnam appeared first time in the top 10 list in the year 2022. This may be because Vietnam is embracing the new fintech and digital banking culture. Vietnam ranked fourth in Southeast Asia for adoption rates of cashless payments in 2021 thanks to the use of digital platforms for 95% of payment services and deposits (Source of Asia, 2022). Vietnam now has a constantly increasing online purchasing population accounting total of 57.6 million users in 2022, an increase of 12 million from 2020.

Also, since 2017, Australia has appeared almost every time in the Top 10 list. This may be because Australia has high Internet Penetration. According to the Australian Bureau of Statistics, in 2020, 86% of Australian households had access to the internet, and 88% of Australians aged 15 and over had used the internet in the previous 12 months. Oceania and Australia make up 0.6% of the 4.66 billion internet users worldwide, according to Internet World Data. 20.3 million Australian internet users make up this 0.6% Oceania and Australia audience in 2020 (Saan, 2022). With more people online, there is a greater potential pool of targets for Phishing attacks.

Besides Brazil and Australia, Portugal is also in the top 10 list frequently. According to *Cost of Phishing and Value of Employee Training Report* by Ponemon Institute LLC (Ponemon Institute LLC., 2015), the cost of dealing with Phishing attacks is about \$3.7 million a year for an average 10,000-employee company. The report surveyed IT professionals in companies ranging in size from 100 to 75,000 employees.

According to Ponemon Institute LLC. (2015), The cost to the organization when Phishing scams victimize employees includes the cost to contain malware, the cost of malware not contained, productivity losses

Table 5
Organizations under attack.

	GIP	Banks	E-Pay	E-com	Social	ISP	IMS	Govt.	Games	Others
2015	31.87%	17.45%	7.80%	9.08%	16.40%	5.50%	3.43%	0.31%	3.69%	4.47%
2016	24.10%	25.76%	11.55%	10.17%	10.91%	4.60%	1.45%	0.95%	3.82%	6.70%
2017	13.49%	27%	15.87%	10.95%	10.82%	7.27%	1.43%	1.31%	1.45%	10.40%
2018	24.72%	21.70%	14.02%	8.95%	8.05%	3.89%	1.12%	8.95%	0.77%	7.89%
2019	21.12%	27.16%	16.67%	7.57%	11.13%	5.23%	1.12%	0.77%	2.29%	5.87%
2020	15.94%	10.72%	8.41%	18.12%	10.02%	4.14%	6.09%	0.5%	0.5%	22.38%
2021	17.27%	11.11%	13.11%	17.61%	6.34%	2.09%	4.36%	1%	1.51%	22.71%

Table 6
Top 3 Targeted Organizations.

	2017	2018	2019	2020	2021	2022
1.	Facebook	Microsoft	Microsoft	Microsoft	Facebook	Facebook
2.	Microsoft	Facebook	Paypal	Facebook	Microsoft	Microsoft
3.	Paypal	Paypal	Netflix	Paypal	C. Agricole	Google

from Phishing, the cost to contain credential compromises, and the cost of credential compromises not contained as in Table 8.

Table 8 shows that almost 50% of costs are caused by productivity losses from Phishing. There are six tasks to perform to resolve a malware incident, which includes Planning, Capturing Intelligence, Evaluating Intelligence, Investigating, Cleaning & Fixing, and Documenting, which takes different time to complete (Ponemon Institute LLC., 2015), and the annual cost to contain malware (spread via Phishing) is based on the hours to complete these tasks. According to Ponemon Institute LLC. (2015), due to Phishing scams, an employee spends an average of 4.16 h in a year, which results in productivity losses from Phishing.

2.2. Analysis of specific Phishing incidents

In this subsection, we present an analysis of specific Phishing attacks and discuss the impact of the attacks.

Table 9 shows an analysis of specific Phishing incidents describing the motives and targets of the attacker, deception techniques used by the attacker to lure the target individuals of the organization, incurred losses to the victim individual/organization, details of the Phisher/Phishing group, and further comments related to the attack. In most cases, the victims, including individuals and organizations, experience financial losses, and in some cases, attackers have targeted personal information, such as health-related information of the victims.

From Table 9, we have made below observations that can be helpful to the research community

1. The aim of major or large-scale Phishing attacks is to cause financial fraud in a direct or indirect manner.
2. Instead of direct financial frauds launched on Banks via direct bank transfers using victim's credential information, the Phishers are now finding it easy to use spoofing to cause an update to a Vendor's bank account number at the payer. In this way, they can bypass the complexity of entering a financial institution via compromising multifactor authentication systems to commit the same fraud. Also, there are fewer traces that are left in this process for an investigation. Such frauds are detected late in time only when the receiver report missing payments to a payer.
3. Spear Phishing is going on with the spread of the Virus and Trojans as a recent addition. More details about spear Phishing will be presented following sub-section. Also, some of these Trojans are being used by the Phishers in targeting multiple entities over several years.
4. Though there are a lot of attacks where the impact is more than 1 million USD the rate of prosecutions or detection of fraudsters is very low. This is because the attacks are launched from outside the Country where the victim has reported the cybercrime. Lack of International laws and evidence or traces are some of the reasons.

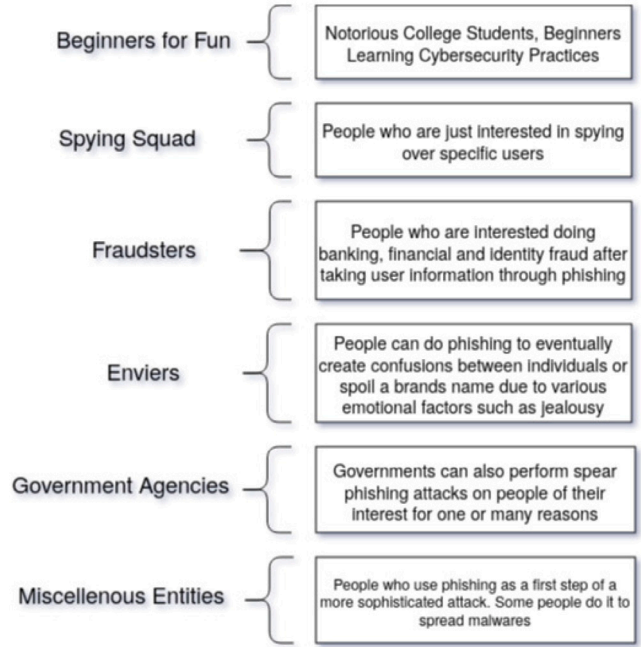


Fig. 1. Classification of Phishers.

2.3. Relationship between Phishers and motives of Phishing

In this section, we have tried to bring a relationship between the type of Phishers and motives of Phishing. Fig. 1 describes the type of Phishers. Though the main aim of any Phisher is to cause a victim to reveal important information or to act on something under deception, we deepen the Phisher's classification based on our understanding of the specific goals that a Phisher is interested in achieving. As shown in Fig. 1, Phishers can be classified as beginners, spying squads, fraudsters, enviars, government agencies, and miscellaneous entities. In Fig. 2, we have tried to describe the motives behind Phishing and then we have connected the Phishing motives with the kinds of Phishers to get a deeper understanding in Table 10.

2.4. Phishing classification based on individuals targeted

Phishing can be classified based on the specifics of the individuals who are targeted. Here we use the term "target" to refer to the individuals on which a Phishing campaign is focused/launched. This classification as shown in Fig. 3, is somewhere based on the number of people phished and the efforts involved in carrying out Phishing on an individual or group.

2.4.1. Spear Phishing

Spear Phishing attacks are targeted on specific individuals which are socially engineered well before the attack is launched (Caputo et al., 2013; Das et al., 2020; TrendMicro, 2019a). Spear Phishing attacks are launched on rich and influential people, a specific government

Table 7
Top 10 Countries by share of attacked users.

	2017	2018	2019	2020	2021	2022
1.	Brazil 29.02%	Brazil 28.28%	Venezuela 31.16%	Brazil 19.94%	Brazil 12.39%	Vietnam 17.03%
2.	Australia 22.15%	Portugal 22.63%	Brazil 30.26%	Portugal 19.73%	France 12.21%	Macau 13.88%
3.	China 19.23%	Australia 20.72%	Greece 25.96%	France 17.93%	Portugal 11.40%	Madagascar 12.04%
4.	Qatar 18.45%	Algeria 20.46%	Portugal 25.63%	Tunisia 17.62%	Mongolia 10.98%	Algeria 11.05%
5.	Bolivia 18.38%	Reunion 20.39%	Australia 25.24%	French Guiana 17.60%	Réunion 10.97%	Ecuador 11.05%
6.	Albania 17.95%	Guatemala 20.34%	Algeria 23.93%	Qatar 17.65%	Brunei 10.89%	Malawi 10.91%
7.	New Zealand 17.85%	Chile 20.09%	Chile 23.84%	Cameroon 17.32%	Madagascar 10.87%	Brunei 10.59%
8.	Portugal 16.76%	Spain 20.05%	Réunion 23.82%	Venezuela 16.84%	Andorra 10.79%	Brazil 10.57%
9.	Angola 16.45%	Venezuela 19.89%	Ecuador 23.53%	Nepal 16.72%	Australia 10.74%	Morocco 10.43%
10.	Russia 16.43%	Russia 19.76%	French Guiana 22.94%	Australia 16.59%	Ecuador 10.73%	Portugal 10.33%

Table 8
Cost of Phishing.

Summarized Calculus on the Cost of Phishing	Estimated Cost
The Cost to Contain Malware	\$208,174
The Cost of Malware not Contained	\$338,098
Productivity Losses from Phishing	\$1,819,923
The Cost to contain Credential Compromises	\$381,920
The Cost of Credential Compromises not Contained	\$1,020,705
Total Extrapolated Cost	\$3,768,820

official, a partner, etc. Spear Phishing always remains well-planned and requires more effort than traditional Phishing attacks launched on random targets. The Phisher generally gets knowledge of their target from social networks and social media. Such attacks are targeted at known people, such as a person the Phisher knows or a person whose significant information is available in public. Spear Phishing attacks are launched especially on those targets, and hence the Phishers know the computer, operating system, or browser the victim is using and may exploit the vulnerabilities in the system before launching a Phishing attack that can make use of it. Spear Phishers may also take the help of family members to compromise a victim or can also learn about the social or personal traits of an individual before launching a Phishing attack. As the attack is specifically targeted it requires great effort from the side of Phishers and also a high probability of getting someone Phishing. An analogy of spear Phishing is a fisherman fishing an important fish in the sea, which might be important to a fisherman because of being costly/precious, or rare.

2.4.2. Whaling

Another classification of Phishing based on targeted victims is whaling. Whaling is a technique to target high-profile individuals (Alabdan, 2020). Such individuals may be the CEO of a company, a top government official, or a top military official having access to sensitive data and information. In whaling, the Phisher can act as a customer or a top official by spoofing their email addresses to cause the government or upper management to look into the matter. A highly escalated customer complaint can reach a top official in a company, and the attachment in the email may cause a virus, such as ransomware, to get installed on his PC. This is a perfect example of how Phishing can be used as a platform to launch other attacks, such as cyber extortion. Phishing can target people in the military and governments to avail access to email and important accounts to get government secrets that may

be of interest to foreign governments. Whaling requires much greater effort as the person being targeted has relatively better knowledge of securing his or her online space. Also, there are many security policies or detection systems that guard him or her against falling into a random or traditional Phishing attempt. The benefits are also many forth if the person is able to perform Whaling successfully.

2.4.3. Random Phishing

As the name suggests, random Phishing is targeted randomly at a large number of people in a hope that at least a few of them will get deceived and will share their credentials or the data requested. This is the most frequently occurring Phishing scam. Lottery scams where people address you without your specific name or Nigerian scams or fraudulent emails from bank officials are examples of random Phishing. The Phishers just know a set of email addresses acquired from some personal data-sharing company. They create an email that is not specially designed for a specific individual, and hence most of such emails address people as *Dear Customer* etc. The Phishers either request the credentials or the data of interest via a reply to emails or via a Phishing link that mimics a Phishing website that can receive the data of interest from the victims. The Phishers do not put much effort into this Phishing attack scenario. The focus is more on the number of people receiving Phishing messages, and the underlying belief is that few of them will get deceived. The act is random, and hence the probability of successful Phishing depends on the number of people targeted and the possibility of such messages reaching those who lack basic IT knowledge. An analogy for random Phishing is a fisherman randomly trying out to find almost any phish in the sea with no intelligent efforts put in place to find out the best fish in the sea or a tactic to find it easily with a high success rate.

2.5. Relation between Phishers and type of Phishing

We demonstrate a correlation between the type of Phisher and the type of Phishing. This comes from the study and the long-term knowledge we have acquired in the area. As you can see in Fig. 4, Beginners are more interested in carrying out Phishing experiments without any planning or targeting a specific individual and hence are expected to launch. Random Phishing most of the time. However, Spying Squad is motivated to perform targeted Phishing that includes specific as well as high-profile targets. Fraudsters' motive is to gain monetary benefits or access benefits, and they can launch it in bulk

Table 9
Phishing incidents.

Attack	Motive	Target individuals/organization	Deception	Losses	Phishers	Comment
Phish Phry (FBI, 2009), March 2009	Account number and passwords of online banking	Bank of America and Wells Fargo Customers	Spoofed emails originated from Egypt asking users to update Internet banking information	1.5 million from approximately 500 victims	Nichole Michelle, Jonathan Preston, Kenneth Joseph from US, and handlers from Egypt	The attackers from US recruited people in US to open new bank accounts to transfer money from compromised accounts and transfer to handlers in Egypt.
RSA Security (Bankvault, 2011), March 2011	Username and password of RSA employees to steal sensitive data from RSA servers	RSA employees	Spoofed emails to RSA employees with title “Recruitment Plan” when opened the mail created a backdoor via a zero-day exploit in Adobe's Flash Player	66 Million USD	Not Available	Complete control of the machine via backdoor helped attacker gain more account passwords.
Phishing scams on Google and Facebook (Fortin, 2019), 2013–2015	Financial Fraud, Money Laundering	Google and Facebook	Attacker launched Business Email Compromise (BEC) scam. Fraud invoices were raised to Google and Facebook spoofing a known hardware company in Taiwan having a business with the targeted companies	Over 100 Million USD	A person named Evaldas Rimasauskas from Lithuania was involved and sentenced to 30 years of jail starting 24th July 2019	Google and Facebook did wire transfers of 23 Million USD and 99 Million USD.
Russian Banks Spear Phishing (TrendMicro, 2016), 2015–2016	Financial fraud, Installing Backdoor	Bank employee, Banking systems	Spear Phishing was launched to spread malware Buhtrap Worm attached with word document causing key loggers and spyware getting installed on targeted machines	25.7 Million USD	Russian Cyber Criminal group IB	Worm infected other machines connected on the Bank network. 13 successful attacks were performed.
Attacks on Banks by Silence (Group-IB, 2019), June 2016–19	Gaining access to victim's banking information and launching malware/backdoor	Russian Banks, Indian Banks, International Financial Forum	Large scale Phishing using spoofed emails posing as banks and asking the user for personal information and downloading attachments with malicious payloads	4.2 Million USD while sending 170 000 Phishing emails	Cyber Criminal group Silence originating from Russia	Started a test Phishing campaign first to finalize active potential targets, attached Silence, downloader malware.
North Carolina County Phishing Scam (Cabarrus County, 2019), 2018	Financial Fraud, BEC	Cabarrus County Staff	The attackers sent spoofed emails to County staff asking to update the bank account details of the contractor for the building of the new high school. The documents were crafted to look original causing staff to update bank details and initiate wire transfer payments	of 1.7 Million USD	Not Available	The attack was detected when the general contractor asked for payments from the County office.
Unatrac Holding Limited BEC Scam (TrendMicro, 2019b), 2019	Financial Fraud, BEC	CFO of Unatrac Holding Limited	Attacker sent an email to CFO which when clicked led to a Phishing page. After receiving the credentials of the Office 365 account of the CFO important files were accessed. The account was used to issue wire transfer requests on bogus invoices	15 fraud payments summing to 11 Million USD	Obinwanne Okeke, CEO of Invictus group, was arrested by the FBI	The email account of the CFO was accessed by a Nigerian IP address around 464 times for various fraudulent purposes
Attack on DHS (Oregon, 2019), Oregon, Jan 2019	Personal health information of individuals	Oregon Department of Human Services	Spear Phishing emails containing a malicious URL was sent to DHS employees leading to a data breach. 9 employee accounts were compromised having 2 million emails containing sensitive data of users	350 000 clients personal health information	Not Available	Information such as client first name, last name, addresses, DoB, SSN, Case Number were leaked.
Phishing attack on Twitter (Wikipedia contributors, 2020), 2020	Financial Fraud, identity theft, money laundering	Twitter Employeeess'	Attackers launched a social engineering attack through phone spear Phishing. Attackers got access to employees' user credentials and the company's internal network. This led to the compromise of many high-profile accounts, which were used by the attackers to promote bitcoin scams.	1 million USD within minutes	Graham Ivan Clark, Mason Sheppard, Joseph O'Connor, and Nima Fazeli	It was deemed as the worst attack on a major social media platform.
bZx crypto heist (Bannister, 2021), 2021	Financial Fraud, BEC	bZx	An attacker breached a developer's computer via Phishing email. The Phishing email had an attachment that the developer executed, and the private key of the cryptocurrency wallet was compromised.	Over 55 million USD worth of crypto	Not available	bZx got alerted to a suspicious activity on November 5 which allowed them to track the IP address of the hacker and also track the stolen cryptocurrencies. They also requested Binance and Tether to freeze the attacker's wallet.
Twilio Employee and Customer Account Compromise (Security, 2022), 2022	Gaining access to internal company resources and stealing customer data	Twilio Customers	An SMS Phishing attack stole employee credentials and led to the theft of customer data. Employees were lured to a fake website resembling Twilio's authentication site, where they entered their login information, which attackers then used to access the real site and steal the customers' sensitive data.	Details of 209 customers and 93 Authy end users' sensitive data was stolen	Not available	Twilio took steps to stop the malicious actor during the Smishing Incident, such as resetting employee account credentials, revoking app sessions, blocking attack indicators, and requesting removal of fake domains.

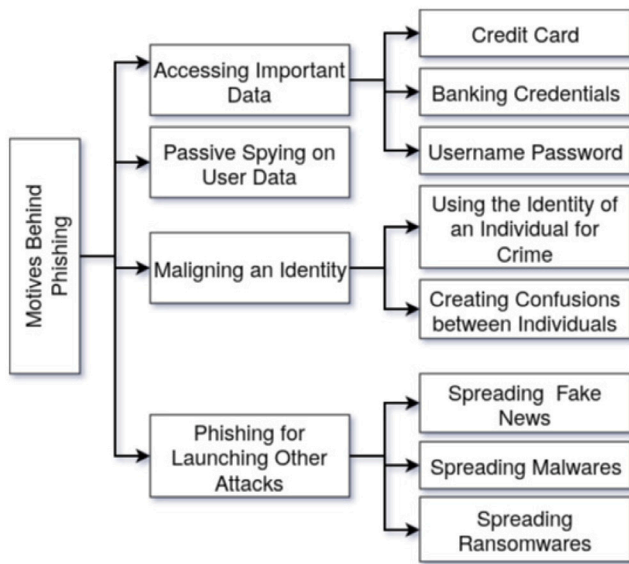


Fig. 2. Motives behind Phishers.

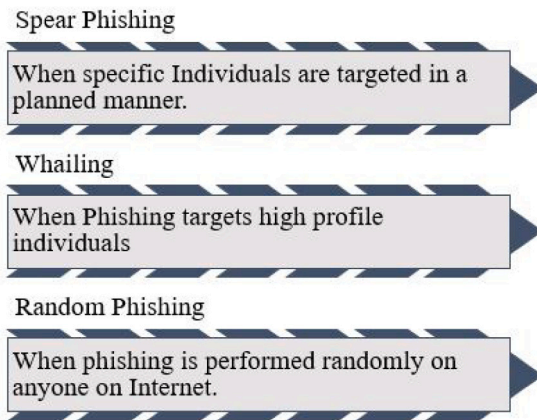


Fig. 3. Classification of Phishing.

randomly or to specific individuals leading to spear Phishing. Enviens are expected to perform Spear Phishing to target individuals based on their motives to be achieved. Daisy chained attack motivation of miscellaneous Phishers can be a part of Spear Phishing, Whaling, or Random Phishing campaigns, as Phishing is used as a stepping stone to launch further attacks, which can be more sophisticated in nature. Though there is a low probability of such a launch on random targets the probability is still significant, and the case is quite logical to be considered here. Government agencies target individuals of high profile are expected. This relationship that we have derived might be an initial understanding that can be studied further by researchers.

Discussion: In this section, we have presented a detailed survey on Phishing attacks on the Internet. In particular, we have analyzed attacks for each quarter over a period of seven years and specific cases of major Phishing attacks. Then we have categorized attackers and their motives for Phishing attacks. We have also categorized attacks based on the victims targeted by the attackers.

Although there is minor variation in the number of attacks observed for each quarter, the attacks are on an increasing trend, and the attacks are becoming more sophisticated. Although several countermeasures such as SPF and DMARC are developed to protect users against Phishing attacks, the attackers are able to dynamically adapt and exploit

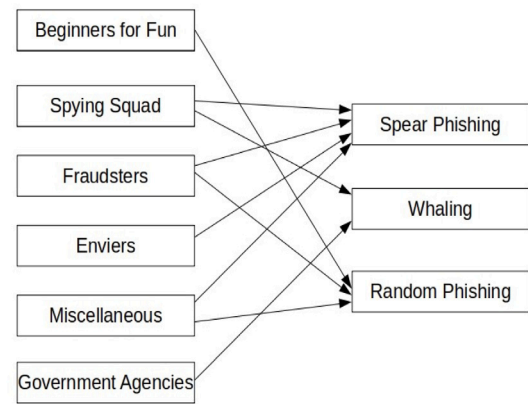


Fig. 4. Mapping between Phishers and type of Phishing performed based on individuals targeted.

weaknesses in the countermeasures to generate Phishing attacks. For instance, none of the Phishing websites were hosted on HTTPS (Fortra's PhishLabs, 2019) before 2016. However, attackers have started using HTTPS for hosting Phishing sites since 2017, and there is a significant rise in the number of Phishing sites hosted on HTTPS. In 2019 58% of Phishing sites are hosted on HTTPS and using SSL.

The one major shift in Phishing attacks is the technology in play, with mobile devices, in particular android devices which account for the majority of online traffic, it is becoming the primary target for Phishers. Phishing is both different and problematic on mobile devices. Most organizations are protected against traditional email-based Phishing attacks through firewalls, secure email gateways, and endpoint protection, also, people are becoming aware of email Phishing scams, but mobile Phishing is a completely different thing than email Phishing. First of all, there is nothing that can filter spam from SMS or text messages, resulting in any kind of malicious spam will be directly sent to the end user. Most users open and read messages reflexively and do not expect to receive malicious messages.

Moreover, mobile SMS does not have any hyperlinks or headers like emails that can help in identifying them and phone numbers are easy to spoof, and the routing through which the SMS is received is not accessible. According to Lookout (2018), the rate at which people are falling for Phishing attacks on mobile devices has grown by an average of 85% every year since 2011.

Therefore, as the technologies and security solutions are growing more advanced day by day, Phishing attacks are becoming more sophisticated with Phishing websites being hosted on HTTPS. Also, mobile devices Phishing has just opened a whole new world for Phishers.

Furthermore, technologies such as IoT and Big Data can make the attacks more worst in the near future. The possibility of more personalized automation with the IoT and the lack of security on IoT devices opens the door for attackers to make use of personalized information for generating attacks. Interestingly, the people managing the organizations such as CXOs who make critical decisions related to the organization including financial decisions lack the technical background and are not aware of the attacks. If the details of such users with higher roles in the organization are compromised, it becomes easier to generate sophisticated attacks using their credentials.

3. Phishing attack tactics

In this Section, we will present a detailed discussion of the different tactics used by the attacker to perform Phishing attacks. In particular, we will consider different redirection techniques used by the attacker to direct the users to the deceptive websites that are controlled by the attacker and then discuss techniques used by the attacker to obtain the sensitive information.

Table 10
Motives behind phishing and phishers involved.

Motive	Description	Phishers involved
Accessing Important Data for Financial Fraud/Identity Fraud	The motive is to get hold of important data such as credit card information or login credentials of an individual for carrying out direct/indirect monetary frauds. The attacker's interest is in getting credentials of an account that can lead to monetary benefits directly	Phishers involved in such attacks include Fraudsters. Beginners are involved with the aim of impressing people by having access to information outside the reach of a normal individual.
Passive Spying on User Data	Spying on user activities on the web through user's credentials obtained via Phishing. The attacker's interest is in monitoring user's activities such as what emails a victim receives in his/her account, what photos one has on the cloud etc. what tenders are available in an account of a top government official or CXO, what someone posts on social media or are friend with.	Phishers majorly include Spying Squad, Government Agencies for intelligence gathering, and Enviars for personal gains.
Maligning an Identity	The Phisher's motive is to use someone's identity acquired through Phishing to send vulgar emails to spoil or degrade his/her identity or use it to tag the victim as an offender of an online crime or create confusion between individuals. The Phishers can increase the frequency of Phishing on specific brands and when the frequency of Phishing increases the user tries to move into a safer online service.	This category mainly includes Enviars [Psychopaths and Sociopaths]. Government entities also use this on their political rivals.
Phishing as an Intermediate platform for Launching other attacks	Here, the Phishing platform is used for installing malware/ransomware under deception. Malicious links in a Phishing email can lead to the installation of malware/ransomware that can encrypt the user data to perform cyber extortion. Compromised accounts of celebrities can be used for bank account updates and the spreading of fake news. Malware can also help cyber criminals to create a command and control channel to launch attacks such as DDoS using the victim's resources.	This category mainly includes miscellaneous Phishers. It is used by Spies for installing key-loggers and Trojans. Fraudsters also use Phishing as a platform to launch ransomware for extortion.

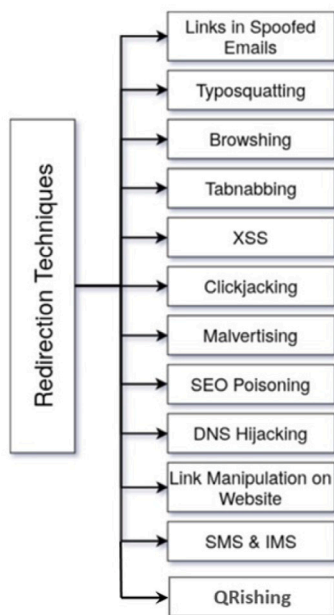


Fig. 5. Classification of redirection techniques.

3.1. Deceptive redirection techniques

Phishing attacks happen mainly due to users being redirected to spoofed websites that look similar to authentic websites in their looks and feel. Attackers create similar-looking websites by copying the HTML contents of genuine sites and hosting them on any free or paid web servers (see Table 11). Then they use various redirection techniques to take victims to deceptive websites, and each such redirection technique has its own specific idealization and properties. Firstly we classify the deceptive user redirection techniques to understand the root cause of credential stealing (over forms, emails, and other platforms) through Phishing in the next phase. The different deceptive redirection techniques are shown in Fig. 5.

3.1.1. Links in spoofed emails

Phishers send spoofed emails mimicking authentic entities to win the confidence of novice users. Spoofed emails are relayed through open SMTP servers, which relay any email without authenticating the sender of the source email IDs. In this way, any sender can pose himself to be an owner of any email ID and get it relayed to any destination email address. The destination SMTP server will unwrap the email headers and show the email to be coming from the source email id, believing that the sending SMTP server had performed the necessary authentication checks on the sender. Once users start believing that the email and its contents belong to an authentic entity (by trusting the displayed sender's email ID), they become ready to perform any action mentioned in the spoofed emails (Avanan, 2019). Often the Phishing email content asks the user to click on a link, which redirects them to a spoofed website or a spoofed login page of a targeted authentic website. This redirection to a deceptive and spoofed website eventually leads to the stealing of user credentials. The main idea used for deception, in this case, is the spoofing of email ids to gain additional trust to get a click on the links mentioned in the emails. One can send such spoofed emails through websites such as emkei.cz or can send it via a PHP Sendmail script after hosting it over any web server. Such scripts are openly available, and SMTP servers which do not enforce SPF, DKIM, or DMARC at the receiving end may not be able to detect such spoofed emails.

3.1.2. Typosquatting

Typosquatting is a technique that relies on mistakes made by innocent users while typing a URL address in the address bar of a browser. The attackers plan this attack by registering domain names with a slight variation in the domain names of popular websites. The variation can be in the domain name itself, which may include misspelled domain names, different top-level domain names, or quite similar country code top-level domain names pertaining to a specific domain name of interest. For example, if facebook.com is the website targeted by the attacker, then he/she may register domain names such as facebook.com, facebook.in, facebook.com, facebook.in.com. The deception is planned, but the redirection to a Phishing website completely relies on the user making a mistake while typing a URL. Such a redirection relies on the carelessness of the user and on the probability that a user will

Table 11
Understanding redirection techniques.

Tactic	Trust angle	Technologies
Links in Spoofed Email	User perform the requested click because the Emails are spoofed and sent via open SMTP servers in a way that the “From” email id matches an official email ID of the organization or bank targeted	Through a simple PHP mail script via using inbuilt mail() function or through websites such as “emkei.cz”
Typosquatting	Begins with the user mistakenly typing the wrong domain name and then the user is not able to differentiate between variations in the domain name of the website loaded	Performed using Homograph Attacks, Bitsquatting, Soundsquatting, Typosquatting Cross-Site Scripting (TXSS)
Browshing	Users install malicious browser extensions available online believing that it will provide them with the services mentioned in the description of the extension, leading them to provide the attacker access to their browser's tab-related data	Attacker updates the input URL website typed by the user using the chrome.tab.update() function (in the case of google chrome) to redirect the user to spoofed websites
Tabnabbing	Users get attracted to certain types of web pages promoting content like celebrity fan blogs, social media-related information, or some kind of adult content. These web pages are designed such that initially they appear very simple and without any malicious intent	Achieved by attackers when onblur property is used to track a user's lost focus event. Once the attacker obtains this, he then changes the appearance of an already loaded webpage to look identical to the login screen of a popular site.
XSS	Some authentic websites suffer from certain vulnerabilities that allow the attacker to run Java script prompts on these websites. These prompts could ask the users to type their login information. Users fall into this trap because they believe it is being asked by the legitimate website itself	Running a JavaScript code on a XSS prone website, a form, through advertisements, through malicious email, for example, A simple JavaScript to execute a prompt function on a vulnerable webpage could lead to stealing of passwords with reflected XSS. This will lead the user to enter the login details on the prompt alert that is displayed. <script>window.prompt(“Enter your login password”)</script>. Users can be redirected to a Phishing site by a script (<script>window.location.assign(“https://Phishingsite.com”)</script>) injection on an XSS vulnerable site.
Clickjacking	Users are deceived into clicking something other than what they visually see on a website as attackers load a transparent Phishing web page over another web page which causes the users to click on invisible content under deception	Clickjacking attacks use CSS to create and manipulate layers. It can also be performed when the pre-population of form inputs using GET parameters prior to submission is done. Another method is to trigger a DOM XSS attack.
Malvertising	Attackers fool the users by showing them promotional offers as advertisements on some well-known websites	Advertisements are run on websites by the attackers through user analytic and foot-printing techniques. Victims click on these advertisements as they contain tempting offers and are redirected to malicious sites or forms.
SEO Poisoning	Attackers design their websites based on the way search engines publish their way of ranking the web pages. Since the attacker is able to show his/her website in the topmost order when compared to authentic websites in search engine results based on the keywords typed by the user, this gives the users false trust that the displayed topmost website is genuine	Attackers use similar description and meta tag information as that of a targeted genuine website leading to their malicious website, Moreover they use crawling bots to increase their indexing on search engine compared to authentic websites. This is done through keyword stuffing. Another method is by creating scripts that recognize if the website is visited by a search engine crawler or by a real visitor. If the first page is visited by a crawler, high-ranking content is served. If the first page is visited by a user, malicious content is served instead, usually using JavaScript and/or redirections.
DNS Hijacking	Since the users do not know much about the Domain-IP mapping process therefore, they fall easily into this trap as they trust the background process of mapping	DNS entries(Domain-IP mapping) of an authentic DNS is misconfigured so that the traffic is redirected to a Phishing website whenever an authentic website IP address resolution is requested. Even the MITM technique could be adopted by the attacker if the communication is being done over an unencrypted channel. Also, it can be achieved if the attackers use a rogue DNS server and redirect traffic anytime. Even DNS manipulation by ISP is possible.
Link Manipulation on Websites	A blogger can host deceptive links behind login over popular social media pages, which when clicked, take the user to Phishing sites	The deception was caused due to a genuine feature of HTML which allows the link text to differ from the actual link address for readability and user-friendliness.
SMS and IMS	Users are tricked by the attackers by making them believe that the messages appearing on their phones are coming from authentic sources. Moreover, the Attacker can buy specific SENDER codes, which makes the user believe that the SMSes are coming from authentic entities and encourages them to click on the links mentioned.	Through sending Phishing URL links in the SMSes or IMS like WhatsApp by posing a business WhatsApp account of a Company.
QRishing	An Attacker can post QR codes under a social media campaign, such as liking a specific page for a cause over a social media site but the QR code takes the victim to a targeted Phishing site requesting a login	QR Codes corresponding to a Phishing URL can be generated easily and presented with textual information of a brand on top of it to look authentic to users.

overlook such misspellings. Once the user does such a mistake, and if the misspelled domain name is registered with an attacker who is mimicking the corresponding popular website, then the user gets eventually redirected to the Phishing page.

3.1.3. Browshing

Source-modified browsers or malicious browser extensions can help Phishers in redirecting users to a phished website. One such example is discovered and coined as a Browshing attack. In Browshing attack, the victim is lured to install a browser extension, which offers some services or perks. Such extensions can be a free video of software download extensions. Such browser extensions hence deceptively get user permissions to access the browser's tab-related data. The browser extension, after some time, starts its malicious behavior by deceptively redirecting the users to a Phishing website URL corresponding to an authentic website URL either typed or clicked by the user. Technically the browser extension takes the input URL through a click or via user typing but calls the tab update functions (`chrome.tab.update()` in case of Google Chrome) in the background to load the attacker's planned Phishing URL corresponding to the authentic website URL typed by the user. As the modification of the URL happens in the background the user is unable to catch the deception. Also, as he/she himself typed the URL earlier, he/she by high probability, will not check the URL again on the address bar once it is updated in the background and finally loaded in the foreground. In this way, an innocent user gives away his/her details on the Phishing URL leading to a successful Phishing attack. The attacker can control the browser extension and can update the targeted authentic website for which the redirection was performed earlier with a new website as well as when and how often this has to be done to the user in the background.

3.1.4. Tabnabbing

Tabnabbing is another technique for achieving user redirection to a Phishing website and was discovered in 2011 by a security researcher. In this technique, the attacker attracts the user to reach his/her website by promoting interesting content such as celebrity fan blogs, and technical or social media-related information. An attacker may also plan to serve some adult content to attract visits to his sites. Once the user visits the attacker's website and, in between, switches to a new tab or another tab on the same browser, the attacker's website gets notified with a lost focus event. When this notification is received, the website executes a JavaScript code that replaces the website content with the login page of a popular social media website or banking website, etc. As the users generally do not remember the exact websites they had left open in various different tabs when they switch back they believe whatever they see is whatever they had left open. Hence when they reach the updated content on the attacker's site (login page of a targeted site) they enter the requested information such as their username and password leading to a successful Phishing attack. The redirection in this case is achieved smartly by tab switching which provides a web page lost focus event to the attacker's script.

3.1.5. Cross site scripting (XSS)

Using Cross Site Scripting attack, the Phisher can launch a login pop-up over an authentic website login page. Cross-Site Scripting vulnerability allows an attacker to run a script on a website having such a vulnerability, eventually compromising the concept of the Same Origin Policy. When such a vulnerability exists, an attacker can cause a JavaScript prompt to be executed whenever the login page URL or any specific URL of a targeted website is loaded on a client. JavaScript can be executed after a certain time on a website as well. Such a pop-up may ask the user to re-enter login credentials showcasing a session time-out message on the website. As the pop-up gets executed over the authentic website, the user will get deceived and believe it is a usual session time-out error message due to prolonged inactivity and reenter the credentials on the redirected login pop-up. This redirection to a Phishing login pop-up is achieved through a vulnerability in the website scripting that does not check for cross-site script executions alongside a web page.

3.1.6. Click-jacking

Click-jacking is a vulnerability identified in 2008. Click-jacking deceives the users into clicking something other than what they visually see on a website. Through click-jacking, users can be redirected to a Phishing website. The attackers load a transparent Phishing webpage over another webpage which causes the users to click on invisible content under deception. This is done to make the user unknowingly click on the "like" button of a YouTube video or "like" a page on Facebook or make a one-click purchase of an item unknowingly through online shopping sites such as Amazon. Click-jacking can also be used for Phishing redirection. To do this, the attacker can place a hidden layer above the targeted website login page. Once the user presses the login button on the authentic page, the button on the hidden layer is clicked instead. This click will redirect the user to a Phishing website showing that the credential entered by the user on the login page did not match. As the redirection happens from an authentic targeted page after the entry of credentials, therefore users are deceived into believing the next page is an authentic one. In the same redirected Phishing page, the attacker requests the user to enter the credentials again. Using such mechanisms, click-jacking can help Phishers to perform redirection to Phishing websites. Click-jacking is also a web vulnerability that can be used for Phishing redirection.

3.1.7. Social media advertising/malvertising

Social media helps the Phishers to understand their targets in a better way using information available from social media and open source intelligence. The information may include targeted users' likes and dislikes, their inclination to a social cause, etc. User analytic and footprinting techniques can help in getting valuable information about a targeted group of users. Once attackers understand their targeted users from social networking websites such as Facebook, Twitter, and Instagram, they spread Phishing URL links as advertisements through their accounts on these social networking websites to the targeted users. They can ask the users to log in to popular websites or like a page or a YouTube channel for a social cause through social media advertising. However, the URL links that appear to take them to a genuine website take the users to corresponding Phishing websites created by the attacker. Social media advertisers can help promote such links on social media, which after a period of time, can serve Phishing content. Social media advertising, in this way, can help attackers to redirect users to Phishing content via bad advertising. Malicious advertising or Malvertising is another way the attackers use to redirect users to Phishing websites. In malvertising, the attackers show deceptive ads alongside the media content either on their own page or on pages belonging to other websites. The deceptive ads could show promotional offers on well-known websites tempting the users to click on them. Once clicked, they are directed to Phishing websites corresponding to authentic websites.

3.1.8. Search engine optimization poisoning

Search Engine Optimization can be used by attackers to show their Phishing website with a higher rank (topmost order) in the search engine results for a specific set of search keywords. Most search engines publish their way of ranking web pages and which can help attackers to design Phishing web pages that eventually can get a higher ranking compared to authentic websites. For example, the attackers on their Phishing sites can use similar descriptions and meta tag information as that of a targeted website that attracts or create more hits on their websites through automated means (crawling bots) to increase their ranking/indexing on a search engine compared to the authentic websites. Hence whenever a set of keywords is searched by a user to search for an authentic website, the search engine will display the Phishing URL link at a higher-ranked position than the authentic website URL link. This can cause deception and make the user click on the higher-ranked search result causing a deceptive redirect to a phished website rather than the authentic website he wanted to visit. Hence search engine poisoning is another way to achieve Phishing redirection and is due to the exploitation of a genuine feature provided by the search engines to promote feature and heuristic-based indexing of web pages.

3.1.9. Host file poisoning, DNS hijacking or DNS poisoning

In host file poisoning, the configurations of the host file of the systems are changed so that the traffic is diverted to a malicious DNS server instead of a real one. The host file on the system maps host names to IP addresses; hence if a file is misconfigured, the request to a trusted host running a local site in an organization will lead to a malicious IP address, which might have a Phishing website running on it. Also, the addresses of local DNS servers are changed to rogue DNS servers by Trojan programs or insiders. The rogue DNS servers direct the user traffic to a Phishing web site's IP address when domain name resolution for the corresponding authentic website is requested by the client. DNS poisoning is another technique where the DNS entries (Domain-IP mapping) of an authentic DNS are misconfigured so that the traffic is redirected to a Phishing website whenever an authentic website IP address resolution is requested. This is also sometimes referred to as pharming when the users get redirected to a Phishing website due to DNS misconfiguration or hijacking. The third case can occur if someone can do modification of DNS packet's transit. This attack can happen over an unencrypted channel. This is a case of MITM, where the attacker can sit in between the client and the DNS server and can sniff the packets, and send a modified version of the DNS response packets to the client with the IP address of the Phishing sites. This vulnerability of DNS can be exploited for Phishing redirection. Also if proper authentication does not exist for modification of DNS zone files and host files in systems anyone can easily use DNS as a platform for Phishing redirection.

3.1.10. Link manipulation on websites

An attacker can inject deceptive URL links in his/her own already running blogs or web pages. Link manipulation is a technique in which the link's actual web address is made to differ from the link title to deceptively redirect the user. For instance, showing links/social media icons for sharing the news or stories on social networking sites with their logos is a very generic thing all news and blogs offer. But what a user sees is just a social media icon of a social networking site. He may not know where the click will redirect him to. In the case of an attacker's website, once a user clicks on the share button, the user is redirected to a Phishing site which in turn requests the user's credentials on the site to share the content. In this way, a manipulated deceptive link is one of the ways a user can be redirected from websites. The same links can also be sent through spoofed emails as well. The deception was caused due to a genuine feature of HTML which allows the link text to differ from the actual link address for readability and user-friendliness.

3.1.11. SMS and Internet messaging services

Novice users can be approached through SMS on mobile phones. The attacker can pose as a bank official and send messages indicating authenticity and urgency and can include Phishing URL links in the SMSs. These links when clicked, take the user to Phishing websites. Users can also be redirected via Internet messaging services such as WhatsApp. A similar technique to that used with SMS can be used to send URL links, which when clicked take the users to Phishing websites. People who are not used to such services (e.g. old people) can be tricked into clicking and doing the requested actions under deception or even using threatening messages. An attacker can buy sending codes that make the user believe that the SMSes are coming from authentic entities to click on the links mentioned.

3.1.12. QRishing

A QR (Quick Response) code is a typical matrix barcode having black and white pixels and is used for easy storage and sharing of small pieces of information. The QR code can be read by a Camera (on a Smartphone or a Desktop) as a picture and can be decoded into readable text or information. Due to the increase in the number of Smartphones, QR codes are being used by a lot of businesses and

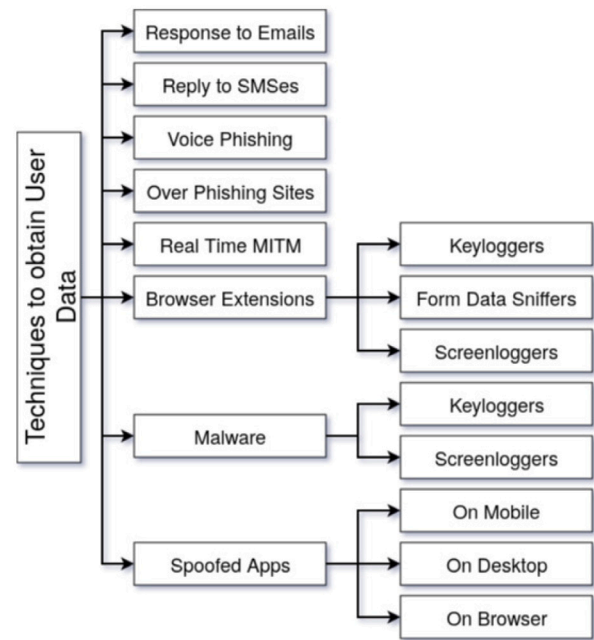


Fig. 6. Techniques for obtaining user credentials.

individuals for sharing their phone numbers, menus in restaurants, and also links to their web portals for login. Since QR codes can be easily generated and distributed to users, this has led to a new form of Phishing redirection which is very easy to execute. Moreover, humans cannot understand the information in a pictorial QR code until it is decoded. Therefore, an attacker could generate and distribute malicious QR codes to users, pretending to be QR codes to a legitimate web portal. After receiving the QR codes, the user scans it and is redirected to a malicious URL where they are asked to provide sensitive information such as username/password, and bank details to the attacker. Attackers can also use URL shortening techniques to fool the victim so that they cannot identify the actual URL where they are being redirected, even when the QR Codes are decoded and displayed before an eventual redirect to the Browser.

3.2. Acquisition of user credentials via Phishing

Phishers generally try to acquire user credentials in the next phase of Phishing using any one of the techniques shown in Fig. 6. In this section, we will present a detailed discussion of each of these techniques.

3.2.1. Response to emails

The attacker generally tricks users into replying to spoofed emails. The email addresses of known officials, organizations and customers are spoofed and sent to the victim users requesting their personal information. For example, the Phishers can spoof customer care email addresses of a flight booking website and send emails to its registered users requesting their credit card numbers. They can provide some legitimate-looking requests, such as the user's last booking has failed or that they want to refund cash back to the user's credit card or a request to verify the credit card details for some previous booking. Such content is aimed at luring the user to reply back with the requested information. The attacker changes their reply-to email address field to point to their personal email address and hence the replies from the victims are received by the Phishers on a separate email account different from the spoofed email address (which actually belongs to the authentic website).

Email spoofing is an attack where the attacker uses the exact email address of a targeted entity to send emails. In the SMTP messaging

protocol, a Mail User Agent (MUA) helps a user to create a message and once the user clicks the send button the email is transferred to the Mail Submission Agent (MSA) of the sender's email service provider over SMTP or HTTP/HTTPS protocol. The Mail Transfer Agent (MTA) of the sender's email service provider then sends the email to the MTA of the receiver's email service provider over SMTP, which is then stored at the Mail Delivery Agent (MDA). The user can then access the received email through email clients or browsers over IMAP, HTTP/HTTPS, or POP protocols. Without email authentication, an attacker can modify the sender's email address (to the victim's email address) and the SMTP servers will still relay the emails. One should note that SMTP does not check whether the person has the right to send the email to that email address when sending messages. It is not difficult to find an open SMTP server or relay SMTP server that can be used for sending spoofed emails in this manner.

To counteract such attacks, there are security extensions for SMTP, including SPF, DKIM, and DMARC. With SPF, Sender Policy Framework, records can be set in the DNS specifying a list of IP addresses allowed to send emails for a given domain. Hence whenever a receiving email server gets a message, the IP address (that delivered the message) is verified to check whether it has been authorized by the domain to which the sender's email address belongs. Hence an attacker cannot just use a relay SMTP and change the sender's email address to a victim's address. Even if the attacker does this, the receiving email server will check the SPF record for the domain of the sender and can easily identify that the IP address of the attacker is not the same as the domain mentioned authorized list of senders allowed to send emails for its domain. Other security extensions such as DKIM allow the senders to add a signature to the email header signed with the sender's private key and let the receiver accept the email only when the public key retrieved from the sender domain's DNS record helps to verify the signature. If the signature is not validated, then the message is not accepted to be genuine. For an attacker to be able to sign the message with the email server's private key requires that the email server domain's key be compromised. DMARC extension provides policies that allow email servers to determine which actions to take when the SPF or DKIM policies fail.

However, as there has not been widespread adoption of such security extensions, it is still possible for attackers to spoof emails in practice. A recent study by [Hu and Wang \(2018\)](#) reported that out of some 1 Million URLs, only 45 percent of SMTP servers follow SPF, and only 4.6 percent follow DKIM protocol. Hence attackers can still send spoofed emails to those domains which do not support SPF or DKIM. There exist many SMTP servers which can be used to relay spoofed emails and there are many online services, such as <https://emkei.cz> and deadfake.com, which can be used by any novice attacker to send spoofed messages. We managed to spoof email through emkei.cz service, which went through successfully to an outlook client. Though the email was identified as spam in our case, the right thing to have done was to prevent this email from reaching the user. Gmail and Yahoo currently block emails sent via online spoofed email services to reach their users.

3.2.2. Reply to SMSs

Phishers can acquire user credentials from the replies to the SMS messages that they have sent. The Phishers can buy a short code (a dedicated code such as 53565) or a long code (such as a virtual mobile number) to make the messages look like messages coming from authentic registered entities such as banks. The user receiving these codes will be led to believe that these are coming from authentic entities leading to them replying with the information requested by the Phishers. Some websites which provide easy registration to generate short codes or long codes include bulk SMS service providers such as mvaayoo. Though they provide the service for benign usage, the Phishers can exploit it for Smishing. Such services can be bought online, and the offered HTTP APIs can be used instantly to send SMSes to the

targeted users. Attackers can close their subscription to this service once their aim is achieved. This makes it easier for even non-tech fraudsters to use SMSes for Phishing users. Some statistics indicate 7 out of 10 people do not take any actions to stop unwanted messages. Around 93% of the adults (aged 18–29) use text messaging services on their phones and send 87.7 texts daily. Teens are more prone to Smishing as 30 percent of the teens receive almost 100 text messages on their phones daily. Some of the recent Smishing attacks include the attack where a customer of a UK bank lost 22 700 pounds. Many lottery scammers use SMS as a way to send SMS to their victims.

3.2.3. Vishing

Voice Phishing happens when someone uses phone calls to deceive users into revealing personal information. As of now, the Phishers are using automated voice-calling systems to call their victims. The automated voice requests users to type or spell their credit card number or personal details which are then used for monetary or identity fraud. The Phishers can also do social engineering to know about their targeted users and their close family members and friends, and record their voices from social media such as videos posted on Facebook, YouTube, etc. A smart Phisher can then impersonate the voice of a family member or friend requesting money to be transferred urgently through social engineering. An alternative method is to call the victim and pose as a bank manager or a government official or a lottery professional using a human voice and deceive the user into revealing their personal information. Phishers can also pose as customer care representatives of a company that the victim had recently purchased some item or can tell the victim of a recent problem they have had with their purchase or bills (known through social media posts). Some Phishers use Vishing to break the two-factor authentication schemes. As most of the secure user logins use some form of one-time password (OTP) as a mechanism in two-factor authentication, Phishers also attempt to trick users into revealing their OTPs on phones. They obtain the username and password of a targeted user and then once an OTP is sent to the customer, they call the customer posing as a bank employee requesting the last OTP received on their phone for verification or for security purposes. In a recent incident an old lady from Mumbai, India lost nearly 700,000 Rupees when she shared the OTP received with a fraudster posing as a bank official. Such cases show how easy it is for Phishers to break the two-factor authentication schemes via Vishing attacks, especially on naive online users.

3.2.4. On Phishing websites

In conventional Phishing, as we have already seen, Phishers direct users to Phishing websites, which look similar to authentic websites duping the victims to reveal sensitive private information. This is the most common form of Phishing over the web. Phishing kits available online allow easy copy and paste, and deployment of HTML web content of targeted Phishing websites. Free hosting servers are used to run the websites obtained from the Phishing kits. Once a user submits the information on the Phishing website, he/she is either redirected to the authentic website login page mentioning that the credentials entered were incorrect or displaying page 404 resource not found or some similar HTTP error messages. Further, this makes it hard for a naive user to observe or report the Phishing website as the user does not see the Phishing website URL once it is redirected to an authentic website after the submission of credentials. All the redirection techniques discussed above are to redirect users to Phishing websites to obtain their credentials over the web.

A hacker with basic knowledge of HTML, web scripting, and web hosting is able to create a Phishing site. Hackers can view and copy the source code of the login webpage (CTRL+U on the browser takes to the source code of any web page on the browser) that they want to use in their Phishing. The form action URL in the source code, which denotes the script which gets executed when the login form is submitted by the user, is manipulated and used in the Phisher scripts

in the modified Phishing webpage. This is done to execute the scripts which will record the username and password on the modified Phishing webpage. Now the webpage is ready to be hosted on a web hosting server. As the source code has not been modified except for the action field (the user never sees the action field) the newly uploaded website on a web hosting server looks exactly similar to the login webpage of the authentic website. The Phishers get hold of similar domain names (such as Faecbook.com, and Fcaebook.com if they are targeting Facebook.com for example) from domain name registering entities such as Godaddy.com, Bluehost, etc. Getting online free web hosting is also easy with several service providers providing free web hosting for a certain period of time (e.g. a couple of months). Phishers then redirect users to the Phishing website using the various techniques mentioned earlier.

Many open-source Phishing toolkits are also available, which can be used to simulate Phishing attacks. Though they exist for increasing awareness of Phishing, when they are in the attackers' hands, they can provide a one-click method to perform Phishing attacks on users. In such cases, knowledge of HTML or web scripting is also not necessary, and the Phisher just needs to know how to run a Phishing campaign through a console. The console provides ways to copy a targeted website login page and host it automatically and send Phishing links through spoofed emails. King-Phiser, Fierece-Phish, and goPhish are examples of freely available Phishing tool kits which can be used by novice attackers to try out some real Phishing attacks.

3.2.5. Real time man-in-the-middle (MITM) phishing

As mentioned earlier, two-factor authentication helps to reduce Phishing attacks by requiring not only the username and password but also a second factor, such as an OTP, a hardware token, or some biometric information. This makes traditional Phishing success limited to only those platforms which still support only single-factor authentication. Real-Time Man Middle refers to Phishers using the man-in-the-middle technique to thwart the authentication procedure between the authentic website and the user in real-time. This can compromise both single-factor and multi-factor authentication schemes.

3.2.6. Malicious browser extension based phishing

Many browsers including popular browser such as Google Chrome allows the developers to create additional functionality on top of the existing browser to provide customized features and user experience. To achieve this, the browser platform provides access to certain APIs that allow the users to read and/or modify the content of the websites opened on the browser. Use of these APIs sometimes can also provide access to the operating system resources such as their files etc. Though the browser extensions were developed for improving the browser experience, it is possible to use them for malicious purposes. In our case, the malicious purpose is stealing user data in the background through deception. For instance, the Phisher can create a malicious browser extension that provides a well-known functionality needed by the users. Such a service is provided to the customers provided they have a certain set of permissions. These permissions are in turn used in the background to steal user data. Such permissions include access to website content opened on the browser tabs through say Tabs API in the case of Google Chrome. Simple offerings such as grammar correction and auto-fill require such privileges. With these privileges, a Phisher can access almost anything a user writes on a webpage in real time, even something the user types in the Search Box of Google or Facebook. The Phisher can also read what the user has submitted on a targeted login page. So if the tabs.URL is set to record the login page of a website, once the user clicks submit, everything typed by the user on that website can be read. In a few of our experiments, we were able to verify that it is actually possible to spy on user activities and record user credentials on any website. Note it is the user who chose to install this extension in the first place, but often users are not aware of what these permissions have the ability to do. Incidentally, often users may

be lured into installing these extensions by giving some incentives such as discounts or gift coupons, making them vulnerable to such stealing tactics.

We have already seen how Browshing can be used to stealthily direct users to Phishing websites which is again another example of malicious browser extensions that are able to carry out Phishing. Some APIs such as desktop capture APIs provided by the Google Chrome platform can be maliciously used to capture browser windows and tab screens to compromise authentication schemes that rely on QR codes, visual passwords, and CAPTCHA. Not only can browser extensions help in storing the secrets through keylogging, form data logging, or screen logging but they can also make Real-Time MITM attacks easier for Phishers. The real-time input of OTP or soft tokens by users on authentic websites can be relayed via malicious browser extensions before the users click on the submit button. This in turn can allow a Phisher to get access to the user's email account with the username and password information known beforehand. The threats from malicious browser extensions can be much more than what we have discussed here, as they depend on the ability of Phishers to create sophisticated Phishing attacks on targeted users. Spear Phishing attacks and whaling attacks can make use of malicious browser extensions to improve the success rate. We have experimented with several such malicious browser extensions, and often they have remained undetected by the web store's internal detection strategies for several days. For instance, we uploaded Browshing extension on the Google web store in a safe mode and found that it remained on the web store for more than 3 months before being flagged as malicious by Google.

3.2.7. Malware

Host-based malware (especially Trojans) can set up command and control channels for Phishers. They can either steal user credentials themselves or can provide a helping hand in a successful Phishing attack. For example, malware can be installed as a user program on the victim's operating system. Similar to browser extensions such programs can provide tools such as photo editing software or PDF merging. In the background, such tools can be maliciously stealing what the user is typing through keylogging or screen logging. Though anti-virus can detect such malware, the use of malicious browser extensions still provides a way to steal user information in real time. One example of malware indirectly helping to phish is the Eurograbber virus which passes the OTP (e.g., from SMS) on the user's phone to the Phisher to perform an OTP-based transaction before the user. Hence such viruses can indirectly help Phishers to compromise two-factor authentication schemes. Host-based malware can also redirect users to Phishing websites using privilege escalation-based attacks, which modify host files as mentioned earlier. Hence malware can play a role in stealing user data in several ways. Such malware can either be installed by an insider or can be spread through Phishing emails, leading to downloading and execution of malware on the victim's machine.

3.2.8. Spoofed apps

Spoofed Apps can record user data during a Phishing attack. These Apps can be Android Apps or iPhone Apps or Desktop Apps or Browser Apps and Extensions. They have similar look and feel to the sign-in pages. The Phishers can spread these Apps and install them on the victim's computer in various ways. The easiest way to get them installed is through a malicious insider or via a person close to the victim. Phishers can also trick users into installing their apps or extensions by publishing a similar App on the web stores, which if the user is paying proper attention will lead to the installation of spoofed apps instead of the real ones. The spoofed apps can also be spread through spurious links on popular websites which advertise them as authentic.

Discussion: In this section we present the techniques used by the attackers to direct the victims to the attacker's website and maliciously acquire their credentials to perform Phishing attacks. In particular,

Table 12
Entertainment.

Scenario name	Rate
Holiday eCard Alerts	24.8%
St. Patrick's Day eCard Alerts	19.7%
Lunar New Year	17.8%
Halloween Costume Guidelines	16.7%
Cricket Big Bash Ticket Giveaway	14.6%
Office Gambling: College Basketball	14.2%
Flash Update Required	13.4%
Cricket International Series Tickets	13.4%
Streaming Football Match	11.6%
Funny Pictures	9.7%

we have discussed techniques such as spoofed Emails, typosquatting, browsing, tabnabbing, cross-site scripting, click-jacking, social media advertising, search engine optimization, host file poisoning, link manipulation on websites, SMS and Internet messaging services to redirect the users to the deceptive websites that are controlled by the attackers. We then considered different techniques used by the attackers to acquire the user credentials. In particular, we have discussed techniques such as Email and SMS responses, deception using voice calls, replication of legitimate websites, man-in-the-middle attacks, malicious browser extensions, malware, and spoofed Apps. Our analysis confirms that there are several entry points for the attackers to direct the victims to the deceptive websites and acquire the user credentials. The attackers are able to easily exploit the weaknesses of TCP/IP communication protocols, and vulnerabilities in the operating systems and applications and make use of readily available toolkits to achieve their goals. Also, critical protocols such as DNS, and NTP still use plain text communication which makes the users easily vulnerable to the attacks. Furthermore, we have presented sophisticated techniques which can be used by the attackers to exploit two-way authentication protocols such as vishing and real-time MITM to obtain user credentials and perform the attack. Hence, with the range of attack techniques available for the attacker, it is not a difficult task for the attackers to lure even skilled IT professionals to the Phishing websites and obtain credentials to generate successful Phishing attacks.

4. Social and cognitive factors behind Phishing

It is very important to understand the social factors as well as the cognitive factors which are involved in the success of a Phishing attack. This is important to understand the right way to start with consumer awareness and government law-making programs to curb Phishing attacks are important. These factors focus on the non-technical side of a Phishing attack which basically deals with the human psychology and cognitive factors which are used by attackers use to plan redirection and credential-stealing techniques for a successful Phishing attack.

Phishing is dependent upon human behavior and awareness of new security trends. Almost all of the victims of Phishing victims are either not aware of how they got targeted or have an emotional motivation towards getting robbed. The Enterprise Phishing Resiliency and Defense Report 2017 (PhishMe, 2017) by Cofense performed a simulation to match the top emotional motivators and made the following observations in their report.

According to Tables 12, 13, 14, 15, 16, 17, 18, 19 Phishers using simulated e-card appeared in the top three: social, entertainment and reward/recognition. Internal promotions also performed very well. We can also see that in entertainment sports related motivators performed well. Several financial and compliance scenarios also had good success rates, which shows that fear is still a strong motivator among all (PhishMe, 2017).

In this paper, we categorize the social and cognitive factors supporting Phishing as shown in Fig. 7.

Table 13
Job function.

Scenario name	Rate
Custom Charges	20.9%
Fin. Info. Review(Attachment)	20.9%
New Fax	19.2%
Please Sign Online	18.7%
Expense Denied	17.9%
Fin. Info. Review(Click Only)	17.6%
Compliance Training(Click Only)	17.2%
Gmail Attachment Scam	15.7%
Compliance Training(Data Entry)	12.6%
Mailinator Scam	12.4%

Table 14
Rewards/Recognition.

Scenario name	Rate
Holiday eCard Alerts	24.8%
New Rewards Program	23.6%
eCard Alerts	22.2%
Employee Satisfaction Survey	17.2%
Life Insurance Policy Documents	16.0%
Free Coffee	15.8%
Employee Raffle	15.5%
Cricket Big Bash Ticket Giveaway	14.6%
Valentines Day eCard	14.4%
Free Lunch	14.3%

Table 15
Social.

Scenario name	Rate
Holiday eCard Alerts	24.8%
eCard Alerts	22.2%
St. Patrick's Day eCard Alerts	19.7%
Thanksgiving Recipe	14.5%
Valentines Day eCard	14.4%
Funny Pictures	9.7%
Brexit Forwarded Email	7.3%
Shared Folder	6.8%
New Chat App	6.2%
Forward From Manager	6.2%

Table 16
Opportunity.

Scenario name	Rate
New Rewards Program	23.6%
Employee Satisfaction Survey	17.2%
Employee Raffle	15.5%
Email Migration(Data Entry)	11.8%
Corporate Rewards	9.2%
Google Docs	7.8%
Summer Flex Hours	7.3%
Email Migration(Click Only)	6.7%
Tax Refund	6.5%
Thanksgiving Deals and Coupons	6.5%

4.1. Inattentional blindness

One of the reasons for the success of Phishing is the lack of attention to detail (Pearson et al., 2017). This can be a social phenomenon as well as a cognitive one. Social because we may see a social group of people defined by age, geography, or level of IT knowledge who may not remain much attentive as an individual who might be very security conscious online. This is a cognitive factor too as Inattentional Blindness can be because of medical reasons wherein your mind remains non-attentive to details. In any case, this reason causes the victim to

Table 17
Fear.

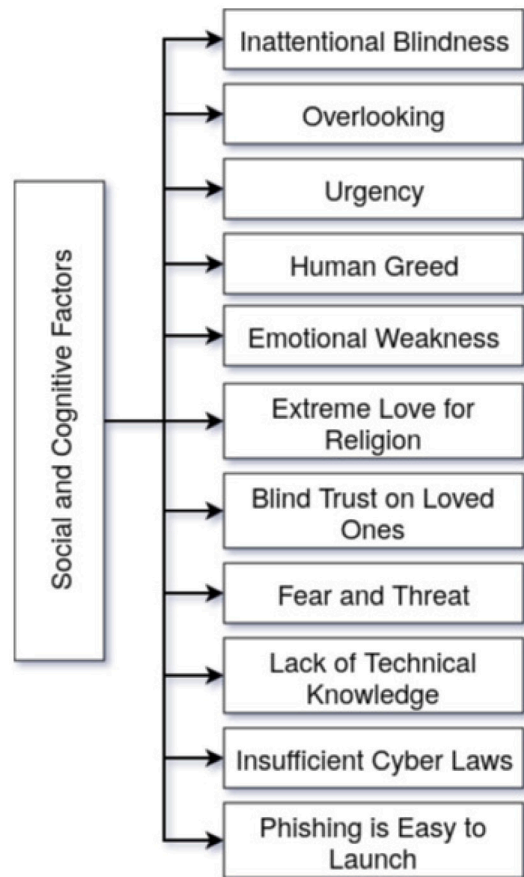
Scenario name	Rate
State Bar Assoc.: Grievance Filed	44.0%
Board of Accountancy: Complaint Filed	34.2%
Ebola Outbreak	27.9%
Mold Found in Office	24.1%
Notice to Appear	24.0%
Money Transfer Reversed	21.7%
HSA Customer Service Email	18.6%
Browser Update Required	18.0%
Expense Denied	17.9%
Bed Bugs Bulletin	17.6%

Table 18
Curiosity.

Scenario name	Rate
State Bar Assoc.: Grievance Filed	44.0%
Board of Accountancy: Complaint Filed	34.2%
Ebola Outbreak	27.9%
Holiday eCards Alert	24.8%
Proforma Invoice	24.5%
Locky Phish	24.2%
Mold Found in Office	24.1%
Notice to Appear	24.0%
Updated Organizational Chart	23.9%
New Rewards Program	23.6%

Table 19
Urgency.

Scenario name	Rate
State Bar Assoc.: Grievance Filed	44.0%
Open Enrollment	39.2%
Board of Accountancy: Complaint Filed	34.2%
Ebola Outbreak	27.9%
Mold Found in Office	24.1%
Notice to Appear	24.0%
New Rewards Program	23.6%
Custom Charges	20.9%
Order Tracking Information	19.7%
Please Sign Online	18.7%

**Fig. 7.** Social and cognitive factors supporting Phishing attacks.

miss checking the URLs (Typosquatting, homographing), focus on the update of malicious content or URLs on the browser tabs (Tabnabbing, Browshing, etc.), identify spoofed websites, spoofed emails, etc.

4.2. Overlooking

Overlooking content is again a social phenomenon that causes successful Phishing attacks (Nagalingam et al., 2015). Most people because of being busy or with a practice of being quick on reply to emails or doing stuff at a faster pace on the Internet generally overlook the details given in emails or websites. This is another reason which helps Phishers as even a trained consumer who has a tendency of overlooking content may not notice the important things mentioned to detect Phishing during a consumer awareness program. A Phishing consumer awareness program may not work if individuals involved in the practice have a behavior of overlooking. Overlooking can help successful Phishing through emails, and websites.

4.3. Urgency

Urgency has an impact on judgment and decision-making. It also affects the speed and accuracy of doing work. The Phishers use urgency as a way to cause a victim do errors even when he may be good with

attention, knowledge of anti-Phishing, and decision-making during any normal scenario. Due to urgency, most people lose their minds and hence do what they might not have done if there was no mention of urgency. A mail that says your account with us will be closed in an hour if you do not reply with details of your bank account may panic a customer who has a big amount stored in that bank. In a panic, he might miss checking the normal details to verify an email or another way of communication during a normal practice (Williams et al., 2018).

4.4. Human greed

Human greed is another reason for a successful Phishing scenario (Desolda et al., 2021). Most people tend to do what is requested by a Phisher because they are lured through money or real estate. Examples include lottery scams where people pass on their bank account details in return for lottery money or a car or real estate that a spoofed lottery manager has promised in an email. Selfishness makes it more difficult to handle Phishing at the right moment because due to selfishness the victim may not discuss the ongoing process with social groups or individuals thinking that they may ask for a share in return. Also, they may not ask their doubts with a technically sound friend or a social group, or government agencies before sharing their personal details with lottery fraudsters because of selfishness. Most of the lottery scams and working mules are a reason for human greed and selfishness.

4.5. Emotional weakness

Many of the Phishers play with emotions to make users do what is requested in an email or on a website or through messages or phone calls (Abroshan et al., 2021). Emotions are the weaknesses of a few

people. If the right social engineering is performed Phishers can know which set of users are emotional for a cause. If they see that you love to support refugees from your Facebook or Twitter posts they may write appropriate content that can touch your emotions to transfer money or do what is requested by the Phisher in an email or on a website. Nigerian scams are an example of how Phishers can play with the emotional weakness of society to perform frauds such as Phishing.

4.6. Extreme love for religion

People can be phished easily if the attacker knows that a group of people support a cause blindly. For example, people of a specific religion or community may get ready to do anything when a cause supporting their own community or religion is falsely justified by the Phisher. Such a case can be seen easily through many social media studies. Most of the time a specific group of people align together on a cause and become ready to do anything blindly such as sharing fake news or taking part in a movement or abusing people on social media. The same can be used by Phishers to spread Phishing links through WhatsApp accounts which may ask users to log in to a website to like a social media content name of religion or community etc. Because of the extreme love towards the community or religion, most people will trust such content blindly and click on links leading to Phishing websites. Such blind love can also result in donating some money to unknown fraudsters in the name of religion or community etc.

4.7. Blind trust on loved ones

One of the other factors that help perform Phishing on high-profile targets and spear Phishing is this. Most of the high-profile targets remain safe from outsiders and from any emotional or cognitive weakness but fail when it comes to trusting the near and dear ones. Phishers also perform whaling and spear Phishing on targeted users by compromising the near and dear ones of a high-profile individual (Downs et al., 2007). For example, a family member using the laptop of a high-profile targeted user can be lured to install a malicious browser extension. As the victim trusts his family members, he will give his laptop with trust to his family members and when he will get it back will not suspect it or check it for viruses or malicious installations. Family members unknowingly install browser extensions and malware that can infect the victim's laptop eventually making the task of Phishing the high-profile targeted user easier for the Phishers.

4.8. Fear and threat

Phishing is taking a new form with hitman scams. In hitman scams, a person targets a high-profile user and sends him a notification that he has received a sum to kill him from someone and will leave him if he pays the sum. This is still under the purview of Phishing as most of the time the people sending such messages are not saying it in real. They just generate fear in an individual to do what is requested (Jansen & van Schaik, 2019). This kind of scam does not come in the media or to the notice of police because the Phishers warn the user to not reveal such information for his own safety from them in the future.

4.9. Lack of technical knowledge

Society has been forced to use Information Technology services in most nations. So in many countries, everything goes online from paying your electricity bills to adding money to a travel smart card. The knowledge of how to use an IT service is given most of the time but how a user should secure himself/herself from frauds such as Phishing is not given on scale. Also whenever Phishers try a new way of doing Phishing the users remain non-updated about such practices. Knowledge of security does not begin from school education, even though the people who use IT services are almost all the youths who

pass school. We give IT security knowledge only when they choose a specific course or only when banks want a user to be secure because they will shift his/her service to a more secure bank. This is a major reason why most individuals are unable to detect Phishing attacks on their own (Mohammad et al., 2015). Most people have no clue about Phishing and those who get the knowledge of it does not remain updated with the new techniques and tricks the Phishers have shifted to for tricking them.

4.10. Insufficient cyber laws

Most governments do not have any specific laws for Phishing. This is a major reason which encourages Phishing as attackers are assured that they will not be caught and prosecuted. Also, the present cyber warriors or cyber security professionals and technologies that the government put forward for curbing Phishing attacks are not anywhere equivalent to the amount needed for preventing or detecting Phishing attacks. Most countries have cyber crime cells which deal with more severe cyber crimes that deal with national security etc. With very less focus or priority on monetary thefts via attacks such as Phishing. Phishers are not tracked seriously in many countries because of the lack of cyber security professionals or specific laws to prosecute them even if they are found guilty. Also if the Phishing is launched outside the reach of a country's law and order there is no way to bring them over and prosecute under cyber laws a country might be enforcing. Also, Phishing is not considered very severe where the information sharing between countries is taken seriously and cyber criminals responsible for Phishing are prosecuted in a country of attack origin. These are some factors that have given rise to Phishing attacks as an attacker does not fear being caught easily and prosecuted.

4.11. Phishing is easy to launch

Phishing is quite easy to launch compared to more sophisticated cyber frauds such as cross-site scripting etc (Ramzan, 2010). For example, creating a spoofed website or spoofed email can be performed through Phishing kits which are easily available for people to try out. It becomes easier for people who are not experts in Information Technology or new beginners in the cyber security field or teenagers to launch Phishing attacks easily. This is another reason which encourages Phishing attacks.

5. Anti phishing solutions

In this section, we present techniques that have been proposed to detect Phishing attacks, techniques for the prevention of Phishing attacks, and also provide discussion on the anti-Phishing awareness and training programs.

5.1. Phishing detection schemes

The schemes that detect Phishing attacks either in real-time or non-real-time are known as Phishing detection schemes. Phishing detection schemes can work on the client side without any server deployment or can work on the server side and provide necessary information to thin clients who might not have enough resources to deploy Phishing detection logic. Majorly we can divide Phishing detection schemes on the basis of the technique utilized for the discrimination of a normal and Phishing website. We have analyzed the complete set of Phishing detection schemes and identified that they can be classified as (1) Search engine based schemes, (2) Machine learning based schemes, (3) Blacklist and Whitelist based techniques, (4) Visual similarity matching schemes, (5) DNS based schemes, (6) Email extensions and (7) scheme for mobile devices, Let us consider them in more detail.

5.1.1. Search engine based schemes

The schemes proposed by [Chang et al. \(2013\)](#), [Chiew et al. \(2015, 2018\)](#), [Dunlop et al. \(2010\)](#), [Huh and Kim \(2011\)](#), [Jain and Gupta \(2018b\)](#), [Ramesh et al. \(2014\)](#), [Rao and Pais \(2019\)](#), [Varshney et al. \(2016\)](#), [Xiang and Hong \(2009\)](#) utilize search engines to discriminate between a Phishing website and a normal website. The core idea behind such schemes is that a normal website will be more popular over search engines over a given identity or feature. For example, the title of a website or its URL or logo will show the website's domain URL among one of the top results when searched over a popular search engine. This is because it is assumed that the URL bears the identity defined by its logo, title, or meta information compared to any other website that might be spoofing it. Also as a Phishing website remains up for a brief period making the probability of them being indexed by any search engine very low. Search engine-based schemes require no resources of their own or very little of such resources as the detection process requires a search query to be performed on search engines. This also makes it suitable to be implemented on the client side as a browser extension service or as a lightweight app without requiring server-side resources. It is less complex but at the same time may not give accurate results when used alone in itself without the cooperation of any other anti-Phishing technique. This is because a standard website may not be popular and may not have an index in search engines, but that does not make it a Phishing website. Similarly, a long-term running normal website can run Phishing campaigns which may not be detected using such a scheme due to the earlier high popularity of the website on search engines. Hence a naive search engine-based scheme may give high false positives in real-world practice. Many researchers utilize search engine-based techniques in amalgamation with other Phishing detection schemes to reduce their disadvantages. Search engine-based techniques generally differ in the number and kind of features utilized for search as well as the number of search engines used for the detection. A classification of the proposed schemes has been shown in [Fig. 8](#). The proposed schemes are classified based on the search query type- text or image. We further divided these schemes based on what text or image feature they used to differentiate between malign and benign websites like page titles, URLs, favicons, or logos. We also classified them based on the search engine they use and the type of data sets that were utilized [like Alexa, PhishTank, or google] for testing the accuracy of the scheme.

5.1.2. Machine learning based schemes

Another set of techniques which were proposed by [Abdelhamid \(2015\)](#), [Abdelhamid et al. \(2014\)](#), [Aburrous et al. \(2010\)](#), [Alhogail and Alsabih \(2021\)](#), [Barracough et al. \(2013\)](#), [He et al. \(2011\)](#), [Homayoun et al. \(2022\)](#), [Indrasiri et al. \(2021\)](#), [Kausar et al. \(2014\)](#), [Ma et al. \(2009\)](#), [Moghimi and Varjani \(2016\)](#), [Mohammad et al. \(2013, 2014a, 2014b\)](#), [Nguyen et al. \(2014\)](#), [Rao et al. \(2022\)](#), [Shahriar and Zulkernine \(2012\)](#), [Singh et al. \(2015\)](#), [Xiang et al. \(2011\)](#), [Xu et al. \(2013\)](#), [Zhuang et al. \(2012\)](#) used for Phishing detection employs the use of machine learning techniques. The core idea behind using such techniques is that features of a Phishing website and a normal website are expected to differ. Though the Phishers try to keep the features of the Phishing website as much the same as that of a Phishing website to deceive the user, some features can still not be spoofed over the Internet. These include URL-based features which require some tweaking to make it look like a normal authentic website's URL as two servers cannot run on the same URL over the Internet. Such tweaking can be easily detected when we feature them as the logic behind any machine-learning approach for Phishing detection. Once important features are identified and extracted from normal and Phishing websites a specific machine-learning algorithm is applied to obtain a model which can classify a Phishing website from a normal one. The trained classification model is eventually used on the client or server end to monitor and detect Phishing websites in real-time. Most machine learning-based classification approaches differ in the amount and kind

of features extracted to train a model and the specific machine learning approach used for training. The disadvantage of machine learning-based approaches is that training the model is costly and require additional and significant resources. Secondly, with time and when the features get bypassed by the Phishers the existing model needs to be retrained. Accuracy and speed also depend on the kinds of features extracted and hence may vary if an intelligent Phisher knows how a model is trained and on what features.

In [Table 20](#) we have classified the schemes in this category based on the type of classifier used for learning, the kind of features extracted for learning, and the accuracy range achieved by various solutions.

Despite the abundance of research on ML-based Phishing detection systems, such as the recent works by authors ([Al-Ahmadi et al., 2022](#); [Alani & Tawfik, 2022](#); [Liu, Geng, & Zhang, 2022](#)), for the purpose of conciseness, we have only addressed a limited number of these studies in our paper.

5.1.3. Phishing blacklist-whitelist based schemes

In these schemes proposed by [Krishnamurthy et al. \(2014\)](#), [Li et al. \(2014\)](#) for Phishing detection a blacklist of Phishing URLs or whitelist of benign URLs is created and updated in real-time in a centralized or distributed repository. The clients utilize this repository whenever a user visits a website and if the URL matches the blacklist warns them of it being a Phishing website. The whitelist or blacklist is created from third-party detection systems or user reporting. For example, a search engine-based Phishing detection system can report the detected website to the blacklist repository which will be verified via a human assessment system to finally get an entry in the blacklist which can then be utilized by other clients to report the website as Phishing more effectively. Another way of reporting includes user reporting wherein a set of reporting via users from anti-Phishing clients can be vetted by a human assessment or automated system to finally add the reported site to the blacklist database. This scheme is generally applied as a filter either at the beginning or the end of an advanced Phishing detection filter. It tries to minimize the efforts that a more complex system must put in to detect Phishing sites by removing negative sites at scale. However, the problem is that it may not detect Phishing sites or detect them but not in real-time as reporting, assessment, and reflection in a centralized repository and its distribution may take some time. There are unique challenges to the implementation of this scheme which include how to store the blacklist and whitelist which increases every day, and if it is stored at a remote server instead of the client's software then how efficiently and frequently it should get updated for timely detection. Whitelist at same time can never be stored on the client's machine due to its drastic size. These techniques generally differ in the method used for creating the blacklist or the whitelist and how it is updated, distributed, and applied at the client's end. Some popular browsers such as Chrome and Firefox use this technique for anti-Phishing as it is lightweight and fast and requires just a single URL match to report Phishing.

In [Fig. 9](#) we have classified the schemes based on what type of list [Blacklist or Whitelist] the solution uses for matching the URLs and the dataset which is used for referencing the URLs.

Recent advancements in the field of Phishing Blacklist-Whitelist based detection systems have been documented in various studies by [Aravena et al. \(2022\)](#), [Azeez et al. \(2021\)](#), [Vidyakeerthi et al. \(2022\)](#). These recent works demonstrate the ongoing progress and advancements in the development of effective Phishing Blacklist-Whitelist detection systems.

5.1.4. Visual similarity matching schemes

There are some schemes proposed by [Chen et al. \(2014\)](#), [Chiew et al. \(2015\)](#), [De Ryck et al. \(2013\)](#), [Lam et al. \(2009\)](#), [Mao et al. \(2013\)](#), [Sarika and Paul \(2014\)](#), [Singh and Tripathy \(2014\)](#), [Unlu and Bicakci \(2010\)](#) which instead of going with text similarity or using text features for classification focuses upon the visual features for Phishing

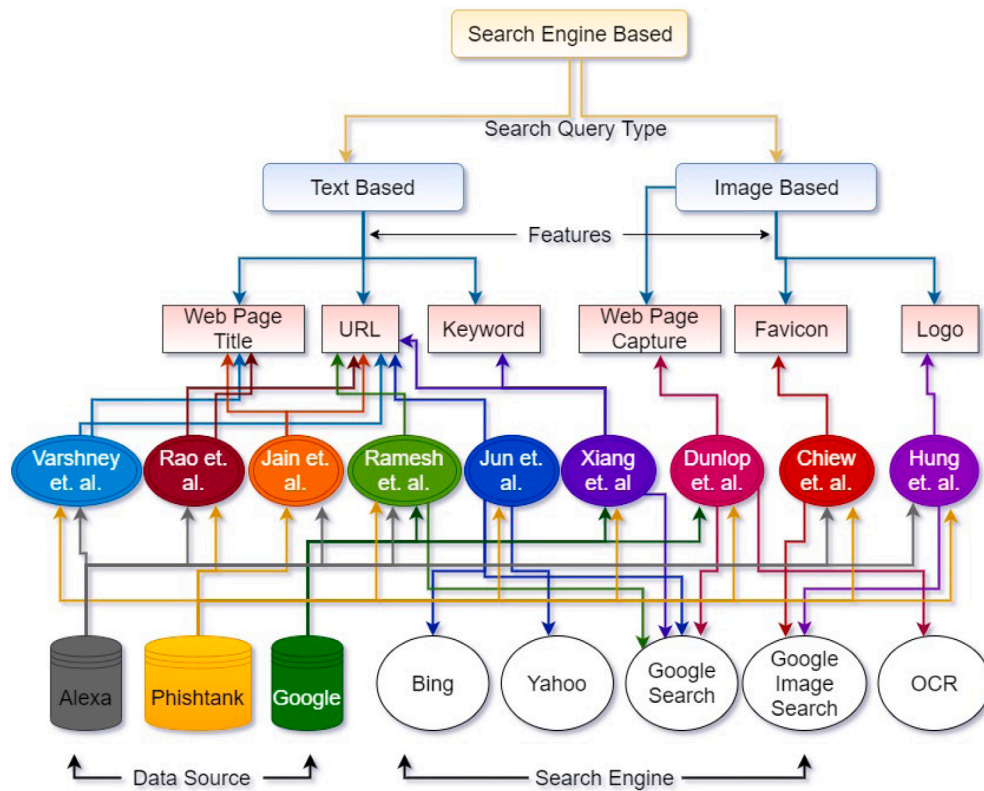


Fig. 8. Search engine based detection schemes.

Table 20
Machine learning based detection schemes.

Papers	Classifier algo used	Accuracy%	Type of features used
Aburrous et al. (2010)	C4.5,CBA,PRISM,RIPPER	NA	URL
Mohammad et al. (2014a)	C4.5,CBA,PRISM,RIPPER	NA	URL,Content,Web,Http,DNS
Shahriar and Zulkernine (2012)	FSM	NA	Content
Barracough et al. (2013)	Fuzzy,Neural	≥95	Law,User,URL,Content,Web
Mohammad et al. (2014b)	Neural	≥90	URL,Content,Web,Http,DNS
Sahingoz et al. (2019)	Decision Tree,Adaboost,SVM,NB,RF	≥95	URL
Rao et al. (2022)	Adaboost,SVM,NB,LR,RF,J48	≥95	URL,Content,Web
Singh et al. (2015)	Neural,SVM	≥95	URL,Content,Web,Http,DNS
Moghim and Varjani (2016)	SVM	≥95	URL,Content
Kausar et al. (2014)	SVM,NB	<90	URL,Web
Xu et al. (2013)	SVM,NB,LR,J48	≥95	URL,Content,Web,Http,DNS,Network,Server
Jain and Gupta (2018a)	SVM,NB	<90	URL
Zhuang et al. (2012)	SVM,NB	≥95	Content
He et al. (2011)	SVM	≥95	URL,Web
Ma et al. (2009)	LR	≥95	URL,Web,DNS
Xiang et al. (2011)	SVM,NB	<90	URL,Content,Web

Note: NA — Not Available, SVM — Support Vector Machine, FSM — Finite State Machine, NB — Naive Bayes, RF — Random Forest, LR — Logistic Regression.

website identification. The idea mimics the way a human sees a website and falls for Phishing which is due to the visual similarity between the Phishing and its authentic target. Visual matching schemes are very effective to detect some of the specialized tricks for Phishing known as Tabnabbing (AzarASK, 2019). In Tabnabbing an attacker creates a genuine website but loads Phishing content on it when the user switches to another tab on the browser. When the user returns he unknowingly enters the credentials on the webpage opened by the attacker thinking that he has himself left the website open for logging in. Visual similarity-based schemes such as one proposed in Tabshots where the snapshots of the website opened on a tab are taken using Chrome APIs. Whenever the user switches back the Tab the webpage snapshot is matched to detect if it is been changed during

switching among tabs on the browser. Other schemes check the CSS layout of pages matching authentic targets to detect the similarity with URL differences as Phishing. Others keep track of favicon, layout, and title changes of a webpage between tab switches to detect Tabnabbing. Image processing and matching techniques are utilized by these schemes. However, there are still a lot of challenges to the success of these schemes which includes platform dependency for the existence of specific pixel matching and Optical Character Recognition APIs. Also, layout and CSS matching may not be feasible for all the authentic targets by client-side software. Lightweight visual matching and image processing-based techniques are required so that client-side software can be developed. Visual matching techniques, however, will always be more complex and not accurate than text matching schemes as dealing

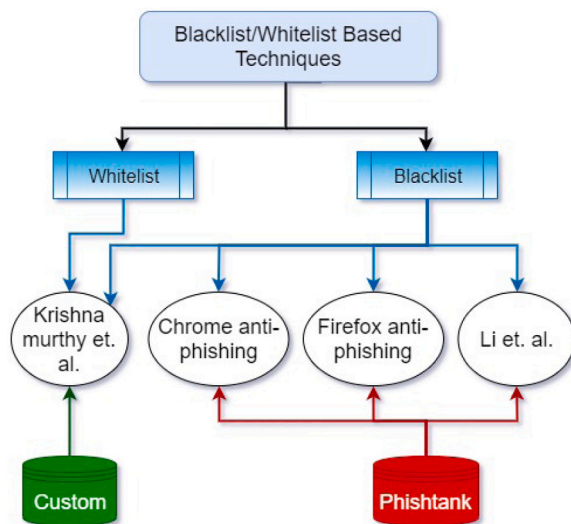


Fig. 9. Blacklist/Whitelist based detection schemes.

with images and visuals require more computation than working with text.

In Fig. 10 you can see that we have divided the scheme based on the type of attack they specifically handle, the features they use for comparisons, and the dataset they have utilized for testing the scheme proposed.

In a recent study by Liu, Lin, et al. (2022), a new approach to Phishing detection has been introduced. This system, based on reference, effectively captures both the intention to imitate a legitimate brand and the intention to steal credentials. This makes it highly resistant to HTML obfuscation attacks. Further, in a recent study by Sanghavi et al. (2022), A new methodology has been proposed to use discrete Fourier transform and image comparison to distinguish between suspicious and genuine webpages. Similarly, Lin et al. (2021) uses Visual similarity matching schemes to detect Phishing attacks.

There are some schemes that do not form a category by themselves due to the sheer number of unique and substantial research that uses them. Still, the use of these specific technique stands out and are described in the below subsections.

5.1.5. Schemes using DNS information

The schemes given by Bin et al. (2010), Bo et al. (2011), Chen et al. (2011), Gastellier-Prevost et al. (2011) focus on the use of the domain's DNS information and IP address information for identifying a Phishing website. Some of the specific use cases include the use of multiple DNS servers to identify the IP address corresponding to a specific domain name. Once the results are available the IP addresses received from multiple DNS servers are matched to find out if the DNS server replying to a bad IP address to a Phishing site. If returned IP addresses are the same the website is considered legitimate. Another way to use DNS was to store and analyze the recursive DNS query logs of a host to identify all the hosts visited by the user to find the suspicious ones. Though DNS is not meant for Phishing detection and many will say that it will increase the burden at the DNS end. However, the way in which DNS is used can be researched in terms of efficiency and optimization. In Fig. 11 we have categorized these schemes based on what type of DNS query (Active DNS Query or Query Logs) they use to differentiate between Phishing and genuine websites. We further divided them based on where they get the IP addresses of genuine and Phishing websites and how they are available to us [as a browser extension or a desktop application].

5.1.6. Schemes involving email extensions

The standards for email security described by Durumeric et al. (2015), Foster et al. (2015), Kambourakis et al. (2020) are the extensions supported by the SMTP protocol which originally could not authenticate the sender and encrypt the content of the mail. STARTTLS, an SMTP extension, mainly shields the messages from passive snoopers by protecting individual hops between SMTP servers and authenticating destination mail servers. Because of the nature of the protocol to guard the hops between individual relays, each relay can willingly read and revise message content. The message and the sender's address are protected using DKIM, which uses digital signatures. DKIM can defend against message forgery and tampering, even against an active attacker. The integrity of DNS responses can be secured using DNSSEC. DNSSEC guarantees the integrity of the DNS RRs by validating them and ensuring that they are not tampered with. DNSSEC was sometimes considered error-prone and impractical. MTA-STS is a standard to affix policy mandates concerning the use of TLS connections and X.509 certificate validation. As MTA-STS does not rely on DNSSEC, active attackers can easily block the DNS responses while fetching an MTA-STS policy. And hence this new scheme has been yet embraced by a tiny percentage of email providers.

5.1.7. Phishing detection schemes for mobile devices

There are a few researchers (Haynes et al., 2021; Wu et al., 2014) who have identified that the challenges to detect or alert users about Phishing websites for mobile devices are more challenging than the same over websites opened on desktop browsers. Also, they have identified that schemes need to be lightweight and utilize the small display available on mobile devices effectively for Phishing detection. Most of such proposals work on whitelisting websites and apps installed on mobile devices and alert the user whenever he/she enters important information on a Phishing app or website. The inclusion of a whitelist of apps deters app spoofing-based Phishing attacks where the attacker tries to put similar-looking apps on app stores and lure the user into installing them to obtain the credentials of the targeted app under consideration.

Finally, we have another set of techniques that can help detect and prevent real-time Phishing attacks. In the paper by Sahingoz et al. (2019), the authors examined the web page's URLs, by making use of distinct classification methods, and natural language processing (NLP) based characteristics to detect real-time Phishing attacks. Armano et al. (2016) in their paper proposed a browser add-on on the client side by utilizing machine learning techniques and computing features from data sources exclusively retrieved by a web browser (beginning URL, landing URL, redirect-chain, recorded links, and HTML source code). In the papers proposed by Quah and Sriganesh (2008), Thennakoon et al. (2019), real-time credit-card fraud detection mechanisms by using machine learning have been proposed.

From our study and analysis of various Phishing detection schemes, we identified a set of points that can be considered by the researchers while designing Phishing detection solutions.

1. Phishing detection approaches should be designed with a hybrid approach. Any single detection method does not cater to all scenarios of Phishing and hence detection schemes that are sufficiently hybrid will detect Phishing more comprehensively and accurately. As individual Phishing detection techniques need to be mixed into a hybrid solution set up researchers need to spend more effort in validating the architectural design of Phishing detection solutions. For example, a comprehensive solution that uses search engine results, important text, URL-based features, and third-party blacklists/whitelists in a collaborative fashion will be zero-day available, efficient, and significantly complete.

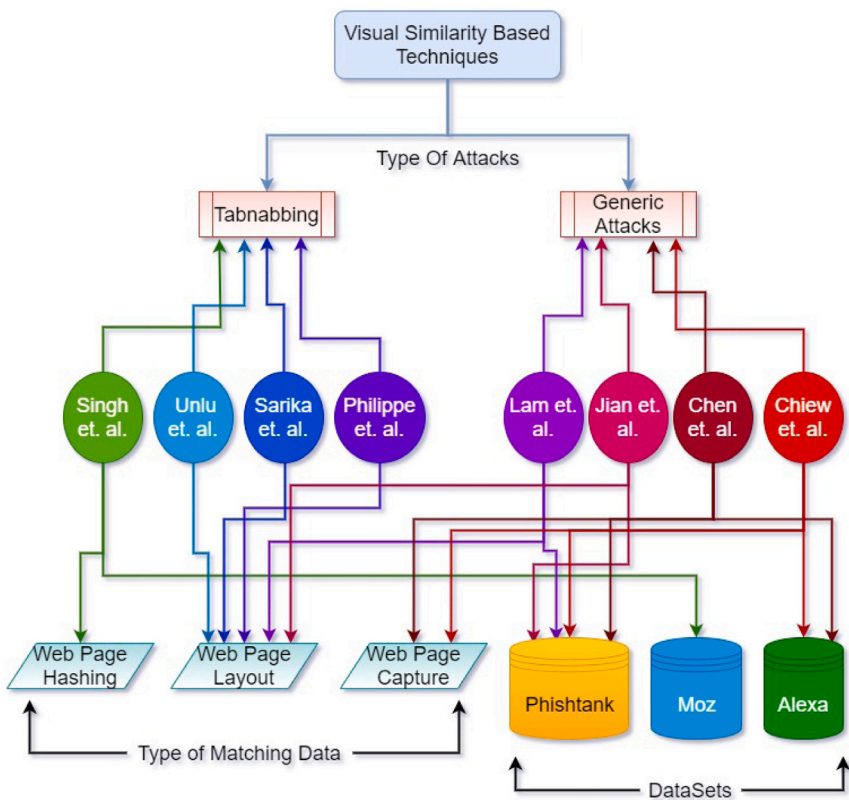


Fig. 10. Visual similarities based detection schemes.

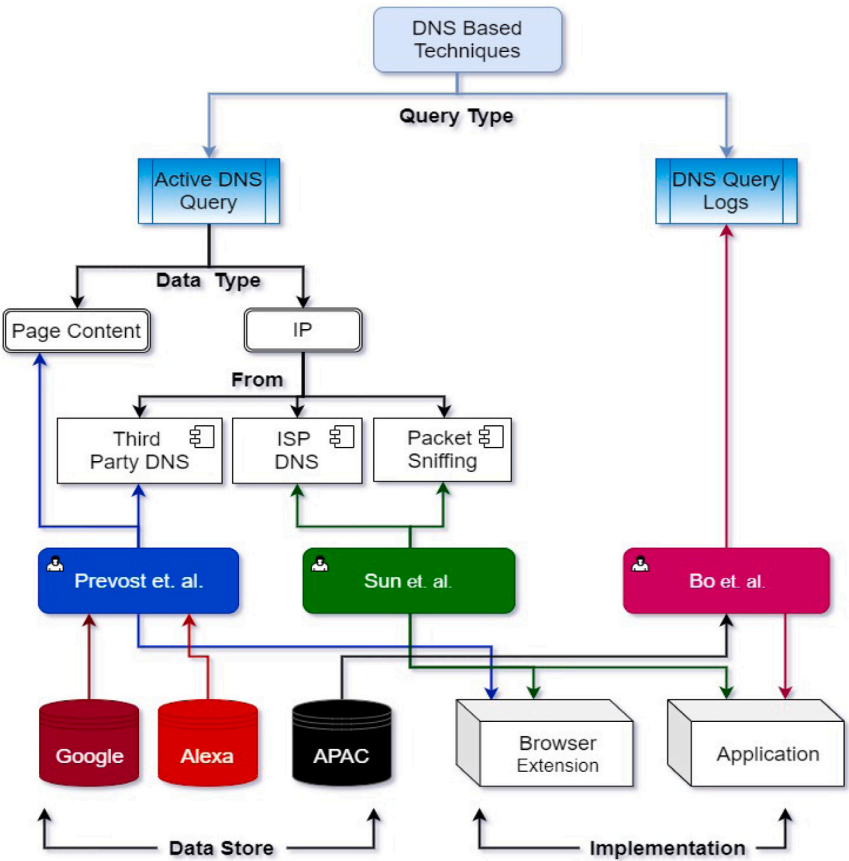


Fig. 11. DNS based detection schemes.

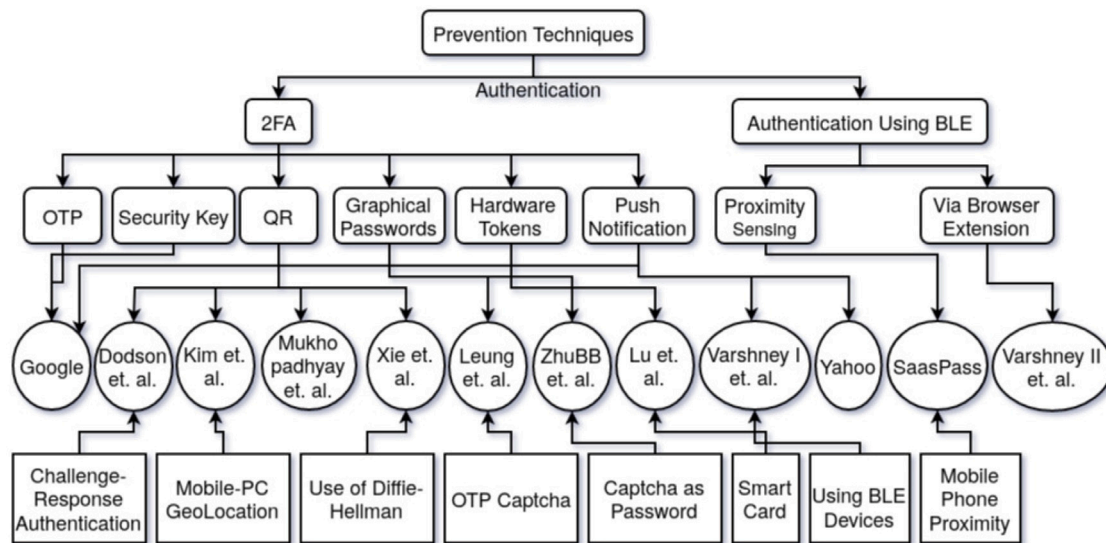


Fig. 12. Phishing prevention techniques.

- Detection solutions must not rely too much on features that come from the evaluation of the trust of a domain name or on features that can be easily spoofed or created or those which are currently not available in Phishing sites but can be easily added at a later date. For example, checking whether a site is running over HTTPS used to provide a sense of trust in the domain in early anti-Phishing days but was realized to be a weak feature when Phishing sites started using TLS certificates for similar domain names to run their content over HTTPS. Features that are long-lived should be used in classification solutions. Also, domains may decide to do Phishing after gaining trust and/or can be hijacked and misused for carrying out Phishing attacks hence the trust of a domain should not be a significant or only factor for Phishing detection in critical security environments.
- The community must look for more unexplored features that can help in building trust. An evaluation of domain trust that does not come from one or two but several features can lead to a better detection solution. For example, security policies used by the domain such as CAA, CSP, TLS chain of trust, and HTTP Security headers can be used to build a comprehensive trust on a domain.
- While it is required that the detection should be accurate it is also required that it happens in real-time and the solution is less complex, feasible, easily deployable, and balances on third-party dependency.

5.2. Phishing prevention schemes

Though there are various Phishing detection schemes available in the market, research in the area of Phishing is equally ongoing. People are working majorly on the development of strong authentication schemes so that it will be hard for a Phisher to spoof the authentication mechanism to obtain the credentials of a victim. Some of the widely known developments in the area of anti-Phishing and user authentication can be categorized into various subtypes. We will discuss some of the major categories of strong authentication schemes here.

In Fig. 12 you can see that we have classified the Phishing Prevention schemes based on whether they are 2-factor/multifactor or uses BLE for authentication. We then categorized them based on the type of secondary, or tertiary token taken for authentication or any sensing utilized during the process. We have also mentioned any specific technique utilized by the scheme for authentication for a quick understanding.

5.2.1. Two factor authentication via OTP/PIN

Many banks have deployed two-factor authentication schemes given by SAASPASS (Baker, 2019; SAASPAAS, 2019), and Google (Google, 2019a, 2019b) for preventing Phishing attacks that use an OTP or a PIN which is made available to the user on the phones via an SMS or notification through a pre-installed app. The notion is that an attacker can steal the username and password but will not have the user's mobile phone and receive the OTP or PIN that needs to be entered as a second factor for login. Though the notion is later found to be incorrect as a real-time Phishing attack. In such a case the Phisher has a real-time communication channel with the victim and hence can request OTP or PIN from the victim on his Phishing websites same as an authentic website request the second factor. Hence without actually having the access to the mobile phone, the Phisher can receive the OTP/PIN in the same way he can receive the username and the password in the very first place. Also, there was some malware that when installed on mobile phones allow them to forward SMS to other mobile numbers. In such a case knowing the username and password someone can attempt a login to an authentic site and can get the SMS forwarded to him/her from the victim's mobile phone running the rouge app/malware. Hence Phishing prevention via the use of OTP or PIN as the second factor is not considered to be a strong authentication mechanism today.

5.2.2. Authentication via QR/barcode

To make it difficult for a Phisher to grab usernames and passwords written as plain text researchers like Dodson et al. (2010), Jindal and Misra (2021), Kim et al. (2013), Mukhopadhyay and Argles (2011), Xie et al. (2015) identified ways through which credentials can be shared in a different format. For the same, bar codes are used by some researchers with some form of secret credentials in the smartphone app of the website installed on the user's smartphone. During authentication, the barcode generated by the website is scanned by the smartphone app and verified. A new barcode is then generated by Smartphone and verified by the PC camera to complete the authentication. As the second factor is not an OTP or PIN or something that the user needs to input the probability of getting a QR code authentication token is much lesser than getting the OTP/PIN via some malicious way. QR codes have been also used for transferring challenges to the user which can then be responded to by performing some function on the secret challenge shared using the private key of the user. Once the response is received and verified the specific users get a login. As the secret resides in the user's smartphone it is very difficult to get the secret information that is required to respond to the challenge to obtain access to user

information. QR codes and barcode hence solves the problem of the previous schemes where it was easy to grab the second factor as clear text as it was input to the websites. One good thing to note here is that as we reduced the user interaction on the website by reducing the need to enter the second factor himself we saw a reduction in the probability of successful Phishing via grabbing the second factor. By automating the challenge-response procedure via sharing information through QR codes which can be automatically scanned and generated the security of the second factor is found to be increased. However, there is a kind of attack that is possible in this kind of authentication. If the attacker can relay the QR Code obtained from the authentic website as an image to the victim then the victim will authenticate the session by responding to the challenge in the QR code from his Smartphone app. This will cause the server to reflect the victim's session on the Phisher's browser. An example of such a scenario has been verified by performing the same in a test environment over what's app web desktop authentication via QR Code.

5.2.3. Graphical passwords and CAPTCHA

Another more sophisticated way of authentication that can prevent Phishing is using a second factor as an image (Alamri et al., 2022; Leung, 2009; Zhu et al., 2014). Password as images were also proposed to make sure that the Phisher is not able to capture the password entered as text on a Phishing website. In password-based authentication, a user can select a set of pictures as a password during registration and has to choose the same among the set of images while logging in. The Phisher has challenges in this authentication scheme first is that it has to identify what kind of images among all has to be there in the image set so that all the different kinds of images chosen by the victim did not get missed. If the Phisher misses any specific kind of image that the victim has in his/her password the victim can easily detect it as Phishing. However, this scheme can be compromised in a different way. A Phisher can capture the screen of the user and can look for the mouse clicks on specific images to know what kind of images forms the password for a specific user. Hence the static passwords must be replaced with something which is dynamic in nature. One of the few proposals involves moving CAPTCHA and Passwords which have to be clicked by the user at the time of the login. There are two benefits the first is that the OTP received is one time and it has to be selected via moving CAPTCHA. This creates multiple challenges for the Phisher. First, he/she cannot create and transfer moving CAPTCHA to its Phishing website without knowing what all characters are in the OTP CAPTCHA received by the user. An incorrectly moving set of characters will flag an anomaly to the user. In other cases, if the Phisher will try to capture the screen of the user understanding clicks on moving objects is more difficult than capturing the same on static picture passwords. However, this difficulty is not really an infeasible one and can help the Phisher break this authentication scheme. Several such authentication schemes that use moving pictures or static pictures or CAPTCHA have been proposed by researchers for anti-Phishing in the past.

5.2.4. Authentication via push login

One of the drawbacks of OTP/PIN, a graphical password as a second factor for authentication has a problem that the user has to input this value. As we earlier discussed that more user interaction leads to more chances of the release of the second factor too. Hence one of the very innovative authentication ways is to send a notification to the authentic user on a second hardware device, such as a mobile phone, and request him/her to just respond with a yes or no to the question asked. A push notification is generated once the user enters the username, password, or sufficient information to verify him/her in the very first place. The push notification comes as a pop-up on a second hardware device such as a smartphone. It usually contains messages which contain a piece of information and request a response to a subsequent question. For example, The Google push notification-based log message contains the information of the place from where the login has been attempted and

the subsequent question is to just verify whether it is the user who is logging in or not. Now if a Phisher tries to log in to a user's account knowing his username and password he still needs to get approval to push notification which is received by the real user. As the real user is not attempting a log in the Phisher will never be able to login to the user session is the security provided by this authentication scheme. Even when it seems very secure and better than the previous authentication scheme, the scheme has an inherent flaw that can be exploited by Phishers. A Phisher can first receive the username and password of the user over a Phishing site and can enter it on the authentic website on his browser. In the meantime, he can show a page that requests the user to approve the push notification received on his/her mobile phone. As he already had entered the credentials on the authentic site it will generate the push notification on the user's mobile device which the victim user will approve thinking that the push notification is for the credentials that he entered for login. Though he did not know that the website he is interacting with is a Phishing website, This real-time Phishing attack scenario can easily break push notification-based login schemes. Though recent modifications to existing push notification-based schemes have been proposed where the website is expected to write secret information on the mobile phone or smartwatch via BLE, and the push notification message is expected to not only take the user response but also initiate the process through which the authentic app can verify whether the secret information written by the website exists in this device or not. Writing secret information via a Phisher to the hardware device of the user is quite tougher than breaching the traditional push notification-based login scheme.

5.2.5. Authentication via separate hardware tokens

Finally we have schemes like Lu et al. (2017) to thwart Phishing attacks and which use separate hardware tokens such as security keys as the second factor for authentication. These hardware tokens such as the RSA key are paired with a user account and they generate OTP or PINs which users can obtain from them in real-time and enter into a website to complete the authentication. Based on the User Id and the specific algorithm the server computes the value of OTP at a particular moment which if matches with the user-supplied credentials confirms user authenticity. Mostly the hard stores some cryptographic information such as a seed and a cryptographic algorithm to generate a secret from the seed. The user needs to register the specific hardware token with his user account and the server knows the specific seed to correspond with it. In this way, the synchronization between the server and hardware with the user is achieved. They are better because they cannot be hacked as the hardware and the software running on top of it is proprietary compared to a cell phone receiving OTP through Apps or SMS. Some hardware tokens such as Yubikey just need to be plugged into the computers and the secret generated is communicated only to the correct website automatically. This reduces the chance of a real-time man-in-the-middle attack. There are techniques such as Tricipher which used multipart credentials and stores a part of the secret key on the user's host machine. Whenever a user enters their username and password the data is encrypted with one part of the credential stored host while is simultaneously signed with another part of the credential stored in the secured data center. The server verifies the signature and the encrypted credentials to allow access. As the credentials are stored securely on hardware and at two places the security increases much forth as the loss of one part of the credential cannot comprise the user authentication. The drawback of such schemes however is that the user has to access his account from trusted hosts only. Hardware tokens based schemes are also costly as you need to buy a hardware token and are also unfriendly as you need to be with the token always to have access. Loss of tokens makes it difficult to access or recover. Though one cannot deny the advantages of hardware token-based schemes being more secure to advance Phishing attacks such as real-time MITM Phishing.

5.2.6. Comparison of authentication schemes

One can compare various authentication schemes with respect to security, deployability, and usability aspects of it. These three aspects are very important to know if a scheme will be adopted for anti-Phishing or not. [Bonneau et al. \(2012\)](#) have defined a very descriptive framework to assess authentication schemes. He identified a few factors in each aspect of the evaluation to help people identify better schemes for authentication for various applications. The parameters of evaluation are as follows:

- Usability
 - Memorywise Effortless
 - Scalable for users
 - Nothing to carry
 - Physically effortless
 - Easy to learn
 - Efficient to use
 - Infrequent errors
 - Easy recovery from loss
- Deployability
 - Accessible
 - Negligible cost per user
 - Server Compatible
 - Browser Compatible
 - Mature
 - Non-proprietary
- Security
 - Resilient to physical observation
 - Resilient to target impersonation
 - Resilient to throttled guessing
 - Resilient to unthrottled guessing
 - Resilient to internal observation
 - Resilient to leaks from other verifiers
 - Resilient to Phishing
 - Resilient to theft
 - No trusted third party
 - Requiring explicit consent
 - Unlinkable

A good scheme must do excellent in any two aspects and will be good in the third one is minimally expected to be used in practice. A scheme with is highly secure may not be the best in deployability and usability aspects but will be accepted to be used at places that require the highest level of security from Phishing attacks. Similarly, a scheme that is less secure but is highly deployable and usable will be used when we need a suitable level of security from Phishing for people who are not very trained to use a high-end secure authentication scheme. Similar applies to other combinations too. A scheme that is just excellent in one aspect may not be a good choice for Phishing prevention. In [Table 21](#) above we have taken two parameters out of three parameters into consideration. We assume that the third parameter is doing good and the parameter in column 1 is doing excellent while those in rows are doing better than the third parameter. In the cells, we have tried to explain the kinds of applications where they will be suited the best. For example, a scheme that is highly usable and sufficiently deployable can have its way to places such as one-touch payments where what is required is high usability and deployability at a suitable security level. NFC payments at point-of-sale devices are an example of such schemes. This table will help to make people understand where a specific scheme must be utilized given its usability, deployability, and security aspects obtained via the [Bonneau J et al.](#) framework.

During our study and research on Phishing and authentication schemes, we have identified that any authentication scheme must have this set of properties to be used in any anti-Phishing environment.

- User Involvement
 - Minimal user involvement in Authentication as users can be tricked in one or another way.
 - Minimal user input with minimal use of conventional methods such as key presses.
- Significant but partial automation, hardware authentication
 - Any scheme must not be completely automated. A fully automated scheme can be compromised easily if the machines involved can be compromised or stolen.
 - The scheme must have a flavor of automation at the same time so that the user tricking to reveal the password will leave him/her uncompromised. Machine/Automation role must be significant but not solely.
- Real-time factors which cannot be relayed in a short time
 - It is very much required that at least one factor used for authentication must be generated and made available to the user or the machines/hardware involved in real-time.
 - The factor must be strong enough to be brute forced and guessed and must be short enough to be communicated in a short time and used by a non-IT pro user.
 - Also the choice of such factors should be such that they cannot be mimicked or relayed in real-time. The efforts of relaying any such credential must be greater than the time after which such credential gets automatically expired after generation.

We believe that if a scheme follows these properties, it is highly unlikely that it will be an easy target for a Phishing attack.

5.3. Anti-phishing awareness & training

As we have seen Phishing is a very dangerous threat to any organization or individual, and not only limited to Banks or Financial Institutions but all other organizations are also the targets of Phishers. Anyone or any organization can become a target of Phishing attacks whether you have a small organization or you are the owner of Google and Facebook like big giants or an end user as we will see in the case study section of this paper. Also, these Phishing attacks have become more sophisticated over time. So what we can do to prevent, detect and fight these Phishing attacks? We gave the answer in sections IV(A) and IV(B) with various techniques given by different researchers. But these all solutions are merely a tool for the end user or an employee of an organization. How the user uses these tools are upon them and if the employee is the weakest link of your organization or if you are an individual end user and do not know anything about Phishing then you are the softest target of the Phishers.

As if you have implemented multi-factor authentication (As discussed in section IV(B)) for your organization and an employee unknowingly gives the password or other authentication keys to the Phishers, then your organization is vulnerable to many unknown attacks. If your employee is not able to differentiate the spoofed Phishing email then the organization is again in big trouble and prone to all other attacks. Therefore the best solution is to train users about Phishing, and like any other training, you need the right tools according to your need at your disposal.

The best way to deal with these situations is to give your employees and end users anti-Phishing training. There are various Anti-Phishing awareness and training programs available that are designed to help reduce employee susceptibility to Phishing. The main methodology behind most of them is as follows

- Step1 Assessment: These programs assess how susceptible your employees are to Phishing attacks. They simulate spear Phishing emails and sent them to observe the employee reactions.

Table 21
Application of an Authentication Scheme Vs Bonneau J et. al parameters.

High/Medium Usability	Usability	Deployability	Security
Usability	Do not Care	One touch payments, single sign-on accesses, etc. NFC payment options.	Non-IT consumer base with sensitive data access. Generic Banking, Social Networking Sites, Online Wallet.
Deployability	Specific Public systems that are accessed mostly by sufficiently IT-educated users. Utility bill inquiry.	Do not Care	Places where IT enabled user use a security sensitive application. University Intranet, ERP.
Security	Premium IT pro consumers, Premium Banking. Military Systems	Public systems used by IT pro professionals such as Income Tax payments	Do not Care

- Step2 Education: The next step involves educating employees about Phishing. The employees are being trained with best practices and educated about the existing detection and prevention techniques.
- Step3 Creation and enforcement of policies: Based on the results of susceptibility assessment, policies are being formed and enforced on employees to follow them.

After step 1, organizations understand where they stand in the fight against Phishing. Then accordingly, they train and educate their employees in step 2, and form and enforce some policies in step 3. These programs train employees to detect and prevent Phishing attacks of all forms and also teach them where and how to report them. We discuss some of the user awareness and training programs as follows.

- There are some online Phishing IQ tests available that can be used to check the Phishing IQ. [PhishingBox \(2019\)](#) contains a questionnaire containing screenshots of actual Phishing and legitimate emails. This test increases the awareness of the user. According to [Anandpara et al. \(2007\)](#), these tests not only increase user awareness but also increase fear in users that makes them more suspicious.
- PhishLabs Security Awareness Training program ([PhishLabs, 2019a](#)) continuously educate the users and motivate them to recognize and report digital risks and Phishing attacks. PhishLabs uses nano-learning training modules to teach users in an easy-to-understand and engaging format. This results in a change in their behavior when they encounter a Phishing attack.
- Cofense PhishMe program ([Cofense, 2019](#)) is an email Phishing simulation solution that is designed to change risky behavior and enable employees to recognize and report Phishing emails. It gives hands-on experience to employees by engaging them in real-life Phishing simulations and analyzing their behavior. It prepares users for the latest real-world scenarios. Apart from that it also comes with extensive and advanced reporting.
- ProofPoint Phishing Awareness Training module ([ProofPoint, 2019](#)) contains 35+ training modules, videos and training materials. It gives two automated tools ThreatSIM for simulated Phishing attacks that find susceptible employees who are then being trained using their 5 to 15-minute Phishing training modules which provide focused training to maximize end-user Phishing awareness. Another tool is PhishAlarm which allows employees to easily report Phishing incidents.
- PhishLine ([Barracuda, 2019](#)) provides security against a range of threats including Phishing, smishing, vishing, and found physical media. It provides easy-to-understand content for training and simulated Phishing. PhishLine is completely customizable. New simulation and training content is added daily, to reflect the most recent threats and training resources available to help protect your business.
- KnowBe4 Kevin Mitnick Security Awareness training program ([KnowBe4, 2019a](#)) provides a 4 step training. The four steps are Baseline testing, Training your users, Phishing your users, and Seeing the results. It provides features like unlimited use, smart groups, custom Phishing and landing pages, simulated attachments, advanced reporting, and new risk scoring.
- MediaPro Security Awareness Training pack ([MediaPro, 2019a](#)) comes with a Phishing simulator, that provides training and simulated Phishing attacks for employees. It empowers employees to identify and respond as part of active defense against Phishing.
- IronScales provides IronSchool ([IronScales, 2019a](#)) A Multi-Level, Gamified, Interactive Micro-Learning Attack Simulation And Phishing Awareness Training program. It provides measurable Phishing awareness training with unique employee scoring to prioritize champion reporters.

Apart from a glimpse of these security training modules we also give some of the best practices that should be followed.

- Never click on the links in an email.
- Always access a website by entering the website address in the browser.
- Always look up phone numbers provided in emails in a legitimate source like phonebook first.
- Never give personal information like bank account details, credit card information, etc. if requested by email.
- Suspect websites that ask for personal information.
- Always uncheck, save this card checkbox while doing online payment.
- Always do online shopping through online wallets and keep only the required balance in these wallets.
- Always study emails first that say urgent action is required as they may be fraudulent.
- Always suspect emails that contain spelling mistakes and grammar mistakes as most organizations use grammar and spell check in their email client.
- Always observe email greetings sent from friends, relatives, and colleagues.
- Always observe the sender's email address and if it is unfamiliar and belongs to a regular sender then, it is suspicious.
- Emails that ask for login credentials, payment information, etc are mostly Phishing emails.
- Emails that are too good to be true can also be Phishing emails.
- If you find any suspicious activity or email always report it to your IT security department.
- Always filter spam.
- Always protect your PCs by installing appropriate antivirus programs and firewalls.
- Never store your passwords on browsers and never share your passwords or any other security keys with anyone.
- Avoid using removable media.

- Always use common sense and if suspect anything then report it.
- Always learn and follow the email policies of your company.
- Always follow security procedures provided by your company, they are for your security.

Discussion: In this Section we have discussed techniques to deal with Phishing attacks. We have discussed in detail different approaches such as detection, prevention, anti-Phishing awareness, and training programs to deal with Phishing attacks.

We have considered detection techniques that are based on search engines, machine learning, blacklisting and whitelisting, visual similarity, DNS information, and email extensions. We have also discussed techniques for detecting attacks on mobile devices.

We have presented a detailed discussion on Phishing prevention techniques using different authentication schemes such as OTP/PIN, QR/Barcode, Graphical Passwords and CAPTCHA, Graphical Passwords and CAPTCHA, Push Login, and Hardware Tokens. We have also presented a comparison of the authentication schemes based on Usability, Deployability, and Security. Furthermore, we have identified some of the properties related to User Involvement, Automation, and Real-time factors for making the prevention techniques robust against Phishing attacks.

We have considered how organizations can make use of Anti-Phishing awareness and Training programs for protecting their employees from Phishing scams. In particular tools from different organizations such as PhishingBox, PhishLabs, PhishMe, ProofPoint, PhishLine, KnowBe4, MediaPro and IronSchool can be used for bringing awareness and/or educating employees to protect from Phishing attacks. Finally, we have identified some of the best practices that can be followed to minimize Phishing attacks.

6. Anti Phishing organizations

Due to the immense rise in Phishing incidents, many organizations have come up with anti-Phishing solutions. They either provide Phishing detection solutions while others provide Phishing prevention or user training solutions. There are companies that also maintain a real-time list of Phishing websites and provide it as a service to other companies for Phishing detection. Such a Phishing list is utilized by browser companies and others to block users reach a Phishing website. Some of the popular companies (as shown in Fig. 13) working in the area of anti-Phishing are described to understand the roles they are playing in securing cyberspace from Phishing attacks.

6.1. Anti Phishing working group

Anti Phishing working group (APWG, 2022) is an organization that has collaborations and membership from industry, academia, government, NGOs, and law enforcement agencies working together to detect and prevent Phishing attacks. APWG was founded by David Jeavns in 2003 and has support from security companies such as BitDefender, Wombat Security, McAfee, Symantec, etc. It has support from its research partners including US-CERT, Truste, etc. APWG from time to time releases Phishing trends reports by compiling the received information about Phishing attacks from various regions around the world through its partners and from public submissions of Phishing attacks. It provides detailed input to its member security agencies, industry, and government agencies that can be utilized to frame the future directions and the specific areas which need to be focused on for anti-Phishing in the future. APWG founded a conference called Symposium on Electronic Crime Research in 2006 and is one of the very few conferences which specifically deals with cybercrime-related research. APWG has also started a cyber security awareness campaign called STOP, THINK, Connect and has engaged 23 nations till now. APWG from time to time release consumer advice to prevent Phishing attacks which help the members from industry and academia to keep

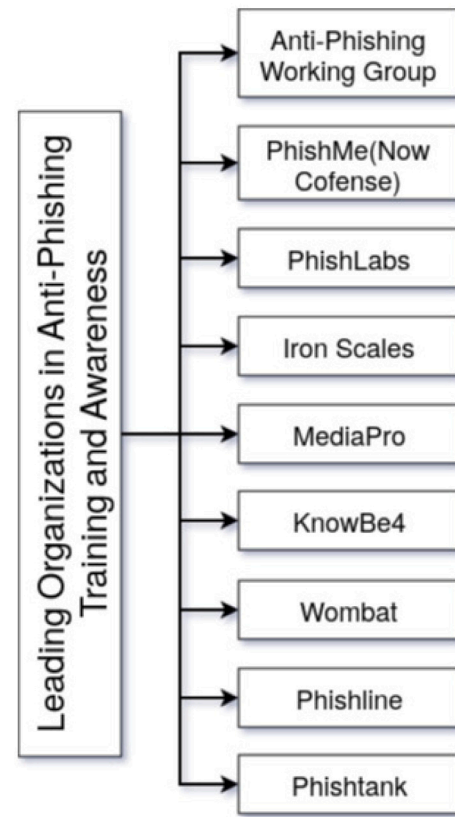


Fig. 13. Leading organizations in anti Phishing, training, and awareness.

its employees or user updated with what they should not do to prevent themselves from falling from targeted Phishing or cybercrime. APWG has an immense contribution to anti-Phishing having 1800 members as of now.

6.2. Cofense

Cofense (2023) previously known as Phishme was founded in 2008. Unlike APWG which is looking forward to Phishing on both the web and email front, the aim of Cofense was to detect and prevent email-based Phishing attacks. Cofense not only provides email Phishing detection to its customers but also provides end-to-end training to its customers or employees of an organization about the prevention, detection, and reporting of email Phishing attacks. Cofense solutions include Cofense Phishme solution which is a Phishing simulation exercise designed by Phishme to help organize and test Phishing-related simulations on its employees. This simulation is used to send Phishing emails which include ransomware, drive-by-download malware, spear Phishing, etc. The organization can check its employees' behavior and the organizational risk from Phishing attacks. Detailed user statistics are provided to the top officials to analyze and plan future directions for training their employees. Cofense also provides a Cofense reporter offering through which a member organization can flag an email as Phishing and allow the Cofense team to directly investigate on it. Cofense also provides its real-time threat intelligence about ongoing Phishing activities via the Cofense Intelligence offering.

6.3. Phishlabs

PhishLabs (2019b) which has now merged BrandProtect into is a leading company in anti-Phishing. Phishlabs deals majorly in all aspects of Phishing and provides a better range of services for an organization

to handle Phishing attacks targeted to its employees. Though its security awareness service is not as discrete as Cofense including Phishing simulation for ransomware and other specific types of Phishing but its landscape of other services is vast and more promising than Cofense. One of the important services is the Social Media Monitoring service which monitors digital risk to senior executives preventing whaling attacks. It also monitors social media threats to an organization and keeps a close watch on it. Dark web monitoring service which is very new on its own helps a customer identify the Phishing kits and Botnet repositories that may harm its employees or resources. It also provides actionable intelligence related to its customer organization which it gathers from the dark web that can help the organization prevent targeted Phishing attacks before its launch. It also provides a service to detect malicious Phishing apps which are using a brand name to get the credentials of its users. Domain name monitoring services and Phishing feeds are also offered as a service. With all these offerings Phishlabs contributes a lot to the online community to thwart active Phishing attacks. Phishlabs also organizes online webinars on anti-Phishing and regularly generates and distributes Phishing activity trend reports based on its intelligence and from attack inputs over a period of time.

6.4. IronScales

IronSights is also a major player in automated Phishing detection solutions, majorly focusing on email Phishing attacks. IronScales (2019b) was founded in 2014 by CEO Eyal Benishti. The company provides a lot of security offerings to prevent email Phishing attempts on employees of an organization. IronSights is one of the offerings which uses machine learning to detect Phishing emails at the mailbox level. It majorly focuses on BEC (Business Email Compromise) threats and uses sender reputation score along with user mailbox profiling to build a model which can flag the emails as Phishing in real-time. It also provides an automated approach for the investigation of a Phishing email once it is flagged as Phishing by the employees using its IronTraps service. Once the email is flagged as Phishing by a user, the email is analyzed by the IronScales built-in technology, which executes the email in a sandbox environment to analyze its intentions. This automation reduces the number of security personnel needed for analyzing email threats in an organization. Once an email is flagged by the system as Phishing, appropriate measures are taken for its mitigation, and the email is forcefully deleted from all the user mailboxes so that other users can be safeguarded from the attack well in time. Federation is a threat intelligence service from IronScales which shares Phishing email incidents with its partners and customers. Once an email Phishing content is found at any customer end, the hash of the email content is shared with IronTraps so that it can delete emails having the same hashed content from other customer mailboxes. IronScales also offer Phishing awareness training to its customers. IronScales hence contributes greatly to the industry in detecting and preventing email Phishing attacks.

6.5. MediaPro

MediaPro (2019b) is a cyber security and privacy awareness organization. The company provides many awareness programs, including security awareness, privacy awareness, GDPR privacy awareness programs, etc. In such programs, the company teaches the employees or its customers about a lot of different topics which are hot in the cyber world and how they can safeguard themselves from being a victim of cybercrime. Some awareness programs talk about social engineering threats, Phishing education, awareness, best practice password guidelines, smartphone security, etc. A very specific contribution of MediaPro in anti-Phishing is its resources for anti-Phishing awareness and a Phishing simulator tool. The Phishing simulator is given as an offering to customer organizations. The tool can launch Phishing campaigns for employees and analyze the results. It provides a set

of email templates that can be used to make spear Phishing emails easy, providing an easy way for security experts to deploy a Phishing campaign. It also provides an email plug-in that employees can use to flag Phishing emails. Unlike other organizations discussed earlier, MediaPro only focuses on user awareness programs for anti-Phishing.

6.6. KnowBe4

KnowBe4 (2019b) is an organization that works to train and aware users of Phishing attacks. It provides solutions lines of MediaPro. The added advantage of KnowBe4 is that it takes into account Phishing, which happens through SMS or voice calls, also termed Smishing and Vishing, respectively. The customer organization can find out the phish-prone percentage of its employees through automated Phishing simulations. The company also provides a lot of resources for anti-Phishing training. The resources include video games, posters, and videos that train the user on Phishing and how to safeguard him/her against such attacks. An individual user-based report is provided at the end of Phishing simulations so that specific employees which got deceived through a Phishing simulation should be given extra training and resources. Some of the training modules provided by KnowBe4 include basic credit card security, CEO frauds, handling sensitive data, social engineering attacks, creating strong passwords, GDPR, mobile device security, ransomware, email spoofing, safe browsing, social media best practices, etc. Kevin Mitnick, who is a well-known security consultant, is known as the Chief Hacking Officer of the company, and some of the offerings of the company are specifically branded with his name, including the Kevin Mitnick Security Awareness Training offering of the KnowBe4. KnowBe4 has been awarded many awards for its anti-Phishing awareness offering, one being the leader Gartner Magic Quadrant.

6.7. Wombat

WombatSecurity (2019) is a anti Phishing focused security service provider. Wombat deals in providing anti-Phishing simulations as well as user awareness and training solutions. Its services include ThreatSim Phishing simulation, where customer organizations can send Phishing emails to their employees and analyze how many fall for it to develop effective training solutions. This is somewhat similar to what other security awareness companies provide. However, a new thing that Wombat provides is ThreatSim USB and SMS simulations. This allows the customer organization to know how many of their employees are prone to USB-based Phishing attacks that can install malware or ransomware to systems. The solution offering also takes into account the scenarios of Smishing, something KnowBe4 also offers. It also provides a cyber strength knowledge assessment platform that provides a set of library questions that can be distributed to employees to know their knowledge of Phishing attacks. The company also provides interactive training modules which can be used by customer organizations to train their employees about anti-Phishing. PhishAlarm service of wombat can be availed, and the customers can report suspected Phishing emails through a client plug-in. The flagged emails are then analyzed through a machine learning-based model, which declares the email content to be Phishing or normal. Wombat is offering a lot of anti-Phishing solutions for a decade and has been recently acquired in March 2018 by Proofpoint Inc.

6.8. Phishline

PhishLine (2019) is a security awareness company that provides its customer organizations with Phishing simulation tool kits that can be used to phish their employees. Phishline covers a variety of Phishing simulation toolkits, including toolkits for web Phishing, Vishing, Smishing, and USB-based Phishing or malware attacks. All toolkits provide good and detailed analysis reports when a simulation is performed by

the organization on its employees. The work of Phishline resembles the offerings of KnowBe4. It also provides other services, including Interactive training modules to train employees about anti-Phishing, risk assessment of employees against Phishing attacks, a Phishing reporting button as a plugin over Windows and Outlook clients, and Google Enterprise solutions. Phishline contributes effectively to anti-Phishing training and awareness and has many partners contributing to it, including Blackfoot and Phishlabs.

6.9. Phishtank

PhishTank (2019) is contributing to anti-Phishing in its own unique way. PhishTank provides a phish verification system. A set of participant organizations and individuals submit Phishing links while other individuals and organizations verify whether the submitted link is a Phishing website. Phishtank hence acts as a real-time repository of Phishing URL links.

Discussion: In this section, we discuss the role of anti-Phishing organizations in Phishing detection and prevention. We can see that a lot of organizations have come up with different mechanisms for detecting and preventing Phishing. These include providing Phishing simulation exercises or tool-kits, anti-Phishing awareness, and training programs providing different resources about preventing Phishing via video games, posters, and videos and providing Phishing trend reports. Although this is the right step taken by these organizations to counter Phishing activities, we believe that the impact of these solutions could be enhanced. This can be achieved if these organizations can reach out to more businesses as well as individuals. They can offer free or cheaper Phishing training and awareness courses, to begin with, and then gradually charge the organizations after the trial version is completed so that it becomes easier for small businesses as well as individuals to understand the usefulness and afford such programs. Moreover, the government should make it mandatory for all businesses to provide their employees with some kind of anti-Phishing training and awareness. Also, these organizations should work on providing a one-stop solution to all the different types of Phishing attacks, whether it is via email, web, or through SMS.

7. Anti Phishing laws

In this section, we discuss the laws related to Phishing attacks in different countries. The selection of countries is based on the entries in [Table 7](#), which contains the data of the top 10 countries by percentage of attacked users and also on the top countries with the highest GDP ([World Bank Group, 2022](#)). We have skipped some of the countries for which sufficient information with respect to direct or indirect laws for Phishing was not available.

7.1. India

Phishing has no direct law in India under the IT Act, 2000 or even after the Act of the amendment, 2008 ([Government of India, 2008](#)). However, Phishing as an offense is punishable under the Indian Penal Code and under Section 66A, 66C, 66D, 66, if IT Act, 2000 ([Government of India, 2008](#)).

1. **Section 66:** If any person, dishonestly or fraudulently, compromises the victim's account by any means of alteration or deletion of data/information related to the user, this is covered and punishable under the law.
2. **Indian Penal Code:** Phishing can be considered as an offense under Chapter XVII(Sections 378 to 462) as offenses against the property of Theft, Cheating, Mischief, Robbery, and Dacoity.

3. **Section 66A:** Punishment for sending offensive messages through any kind of communication service is provided under the Section. Deceiving or misleading the recipient of banks or other organizations by containing a fake link in a disguised email clearly attracts the punishment under 66 A, IT Act 2000.
4. **Section 66C:** The Amendment Act, 2008 inserted the Section 66C into the IT Act, 2000. It basically covers the punishment for Identity Theft which is provoked in case a person fraudulently makes use of a password, key, electronic signature, or some other identifying technique. e.g If a fraudster disguises himself as a genuine banker and is using some unique identification feature of the banking organization like some copyright material, trademark, or logo, it clearly falls under the provisions for Section 66C.
5. **Section 66D:** This section provides for "Punishment for cheating by impersonation by using computer resource". Thus, the fake Phishing emails intended for fraud or crime clearly fall under the provisions of the Section.
6. **Section 66E:** The Section 66E provides for "Punishment for violation of privacy". Although it does not directly concern Phishing and emails, in case a fraudster deceptively uses the Phishing emails to get a hand on personal user data like his/her email id, password, and banking details, this activity is indirectly covered and punishable under Section 66E.

7.2. US

The first lawsuit against a Phisher in the United States of America was filed by US Federal Trade Commission on January 26, 2004. The accused was a teenager from California who stole credit card information using a website created allegedly to look similar to the AmericaOnline website. After this incident, Anti-Phishing Act was introduced in Congress by Senator P. Leahy in March 2005. The criminals who sent fake emails and created bogus web pages to defraud users on the internet were to be punished under the Act, but unfortunately, it did not pass. Eventually, in January 2007, a Californian named J.B. Goodin was convicted as the first cybercriminal for sending hundreds of fake emails and prompting American Online users to submit financial information like credit cards. He was convicted under the CAN-SPAM Act of 2003. It also establishes the National Standards for commercial email and oversees the Punishment for violating privacy. Any person or business who violates the Act can be charged up to \$11000 for each such violation.

7.2.1. Federal laws (indirect)

No federal legislation in the United States pertains specifically to Phishing activities. The Anti-Phishing acts of 2004 and 2005 inculcated sheer penalties on those convicted of Phishing activities. Although these bills ultimately died and were never executed, according to the summary of these bills as and if the bills were imposed, they would have served the following purpose:

- Anti-Phishing Act of 2005 — The amendment to the Federal criminal code criminalizes the acts of obtaining sensitive information from people using various internet-driven scams (Phishing).
- A penalty is imposed, which may be either a monetary charge or prison punishment of upto five years, and in some cases both, for someone who consciously engages in some activity that involves fraud or identity theft under the Federal or State law: (1) creating or aiding the creation of a website or domain which claims itself to be a genuine online business but have not obtained proper licenses and/or permissions from the regulatory authorities of those businesses; and (2) using an online entity like a website or domain name to attempt to ask for identification sources from anyone.

- A penalty is imposed, which may be either a monetary charge or prison punishment of upto five years, and in some cases both, for someone who consciously engages in some activity that involves fraud or identity theft under the Federal or State law circulates an E-Mail that: (1) wrongly claiming it to be sent from a genuine online business; (2) uses some methods that refer the users to an online location which wrongly claims itself to be from a genuine online business; and (3) asks for sensitive information from the person who received these mails.

However, the proposal never got turned into law because it did not survive by the concerned authorities. Despite that, the federal government can give punishment to those who do these criminal activities by some other means. As of now, there is no federal law that addresses only Phishing. So businesses and organizations take care of preventing Phishing and other similar activities by some set of rules at the organization level itself.

HIPAA. The Health Insurance Portability and Accountability Act ([Health & Human Services, 2005](#)) is applicable to every business and organization that uses or produces any kind of medical records by any means. It is used to regulate any doctor or hospital, as well as other organization that stores and uses that data, such as records cleaning the house, insurance company, and places where these records are stored, like a warehouse. Although this has a vast range, the main focus of this act is to ensure the creation and maintenance of security awareness within the organization through various campaigns and surveys. This involves providing proper training to the employees and other concerned individuals for identifying and avoiding possible security threats so that the patient and company data is secured.

SOX. The founding purpose of the Sarbanes-Oxley Act(SOX) ([Government of USA, 2002](#)) was to make financial reports a necessary regulatory activity for organizations from all sectors. It affects the regulations for storing, using, and destroying the data pertaining to the finances of people. Almost all private and public organizations in the United States come under this act, it does not matter which field of work they are involved in. SOX does not specify electronic mail security, but 302 and 404 handle the compliance policy and electronic mail-based precautions, to ensure the safety of Phishing and similar threats for an organization.

PCI-DSS. The Payment Card Industry Data Security Standard (PCI-DSS) ([P.C.I. Security Standards Council, 2019](#)) is, as the name suggests, an industry’s regulatory system not involving the federal government. Any organization that deals with debit/credit card information, have to comply with this standard. It involves training the individuals in the organization at any level to be familiar with certain regulations and measures which ensure the protection of this sensitive information so that it does not fall into the wrong hands.

7.2.2. State laws (direct)

Twenty-three states and Guam have laws specifically aimed at Phishing schemes (see [Table 22](#)). The first state to pass stringent anti-Phishing laws was California, and many of the states that eventually passed similar legislation followed California’s lead. What does California’s anti-Phishing law look like?

- It is called the Anti-Phishing Act of 2005 (identical naming to the failed federal bill that died in committee).
- It makes it illegal for anyone to use a website, email or other Internet-based methods to “solicit, request, or take any action to induce another person to provide identifying information by representing itself to be a business without the authority or approval of the business”.
- Note that “identifying information” in the state of California includes the following items:

Table 22

State laws addressing the term “Phishing”.

State	Statutory citation
Guam	5 GCA §§32703,32704 (h)
Illinois	740 ILCS §§7/1-7/15
Alabama	Ala. Code §13A-8-114
Arkansas	Ark. Code §§4-111-102,4-111-103
Arizona	Ariz. Rev. Stat. §§18-541-544
California	Cal. Bus & Prof. Code §§22948-22948.3
Connecticut	Conn. Gen. Stat. §53-454
Florida	Fla. Stat. §§668.701-.705
Georgia	Ga. Code §16-9-109.1
Kentucky	Ky. Rev. Stat. §Stat.434.697
Louisiana	La. Rev. Stat. §§51:202
Michigan	MCL §445.67a
Minnesota	Minn. Stat. §609.527, Subd.5a
Montana	Mont. Code Ann. §§30-14-1712, 33-19-410
New Mexico	N.M. Stat. §30-16-24.1
New York	N.Y. Gen. Bus. §390-b
Oklahoma	Okla. Stat. tit. 15, §§776.8-776.12
Oregon	Ore. Rev. Stat. §646.A.808
Rhode Island	R.I. Gen. Laws §§11-52.1-1 to -5
Tennessee	Tenn. Code §§47-18-5201 to 47-18-5205
Texas	Tex. Business and Commerce Code §§325.001-.006
Utah	Utah Code §§13-40-201 to -204,-401
Virginia	Virginia Code Ann. §18.2-152.5:1
Washington	Wash. Rev. Code §§19.190.080-090-100

- Social Security number
- Driver’s license number
- Bank account number
- Credit/debit card numbers
- PINs
- Electronic signatures
- Biometric data
- Account passwords
- “Any other piece of information that can be used to access an individual’s financial accounts or to obtain goods or services”.

7.3. UK

The Fraud Act, 2006 ([Government of U.K., 2006](#)) was passed in the United Kingdom for the states of England, Northern Ireland, and Wales. The Fraud Act came into existence on January 15, 2007. There was not any law that properly dealt with Phishing before this. It bans the use of Phishing tools/kits for mailing bogus emails on a large scale. This act punishes (1) fraud by false representation, (2) fraud by abusing position, and (3) fraud by failing to disclose information. The individual or party convicted of the crime is liable to be fined or imprisoned from twelve months to up to ten years depending on the type of conviction.

7.4. Australia

As Phishing is effectively a form of identity theft, most forms of Phishing could be criminally prosecuted under state legislation that generally deals with identity theft and fraud:

- **Crimes Act 1958** (Vic): obtaining property by deception (s 81(1)), and obtaining financial advantage by deception (s 82) ([Government of Australia, 2019b](#))
- **Crimes Act 1900** (NSW): obtaining money by deception (s 178BA), obtaining money by false or misleading statements (s 178BB), obtaining credit by fraud (s 178C), false pretenses (s 179), and fraudulent personation (s 184) ([Government of Australia, 2019a](#))

- **Criminal Code** (WA): fraud (s 409(1))
- **Criminal Code Act 1924** (Tas): dishonestly acquiring a financial advantage (s 252A(1)), and inserting false information on data (s 257E) ([Government of Australia, 2019c](#))
- **Criminal Code 2002** (ACT): obtaining financial advantage by deception (s 332), and general dishonesty (s 333) ([Australian Capital Territory, 2002](#))
- **Criminal Law Consolidation Act 1935** (SA): false identity (s 144B), and misuse of personal identification information (s 144C). These provisions were introduced by the Criminal Law Consolidation (Identity Theft) Amendment Act 2004 (SA) to specifically address identity theft ([Government of Australia, 2019d](#)).

7.5. Brazil

The Criminal Code was amended on May 27, 2021, by a law approved by Brazilian President Jair Bolsonaro to increase the severity of theft and fraud offenses committed online or through computer device violations.

The new law, Lei No. 14.155, de Maio 27, 2021, toughens up the penalties for anyone caught breaking into another person's computer system, whether it is online or not, to steal, alter, or destroy data or information without the owner's express or implied consent, or to introduce vulnerabilities to gain an unfair advantage. The prior sentence of three months in prison and a fine has been extended to one to four years in prison and a fine, (CP article 154-A).

Penal Code article 155(4-B), which is part of Law No. 14.155, punishes theft committed through fraud when using an electronic or computer device, whether it is connected to the Internet or not, with or without a security mechanism being violated, with or without the use of malicious software, or by any other similar fraudulent means. For such crimes the penalties imposed are four to eight years in prison and a fine, (Article 155(4)(C(II))). [Soares \(2021\)](#).

7.6. Switzerland

According to the Swiss Criminal code (SCC), these are the offenses that cover Phishing ([Global Legal Group, 2022g](#)):

- According to art. 143 para. 1, a person involved in an Unauthorized obtainment of data would be liable to a custodial sentence of up to 5 years or a monetary penalty may be imposed.
- According to art. 179, a person involved in the obtainment of personal data without authorization would be liable to a custodial sentence of up to 3 years or a monetary penalty may be imposed.
- According to art. 251, a person involved in the forgery of a document, would be liable to a custodial sentence of up to 5 years or a monetary penalty may be imposed.
- According to art. 147, a person involved in Computer fraud, would be liable to a custodial sentence of up to 5 years or a monetary penalty may be imposed.

In the year 2019, the first prosecution and conviction for the act of voice Phishing were observed there.

7.7. France

According to the French Criminal code (FCC) and Intellectual property code, these are the articles that sanction Phishing ([Global Legal Group, 2022b](#)):

- According to art. 226–18 of FCC, a person involved in the collection of data by fraudulent or unlawful techniques, would be liable to imprisonment up to 5 years and a monetary penalty of 300,000 euros would be imposed.

- According to art. 226-4-1 of FCC, a person involved in the use of a third-party identity, would be liable to imprisonment for up to 1 year and a monetary penalty of 15,000 euros would be imposed.
- According to art. 313-1 of FCC, a person involved in fraud or swindling, would be liable to imprisonment of up to 5 years and a monetary penalty of 375,000 euros would be imposed.
- According to art. 323-3 of FCC, a person involved in the unauthorized introduction of data in a system, the use of data, extraction, or reproduction, would be liable to imprisonment of up to 5 years and a monetary penalty of 150,000 euros would be imposed.
- According to art. L.335-2, L.713-2, and L.713-3 of FICC, a person involved in the infringement of intellectual property rights, would be liable to imprisonment of up to 3 years and a monetary penalty of 300,000 euros would be imposed.

7.8. Japan

According to article 7 of the Unauthorized computer access law (UACL) of Japan, Phishing is prohibited. Also, in article 4 of UACL, obtaining any identification code through Phishing is prohibited. A person involved in such an act would be liable to imprisonment of up to 1 year, or a monetary penalty of JPY 500,000 would be imposed according to article 12 ([Global Legal Group, 2022e](#)).

7.9. Italy

According to article 640ter of the Italian Penal Code (IPC), a person involved in altering the normal working of a computer or tampering with the data for monetary or other benefits would be punishable. Moreover the article 640ter, para. 3, says that if electronic fraud is done via stealing or without authorization of the third party's identity would lead to imprisonment for 2 to 6 years and a monetary penalty of 600 to 3000 Euros would be imposed ([Global Legal Group, 2022d](#)).

7.10. Germany

According to section 263a of the German Criminal Code (Computer fraud), a person involved in the unlawful interception of data and then using the data for their benefit would be liable for imprisonment up to 5 years, or a monetary penalty would be imposed ([Global Legal Group, 2022c](#)).

7.11. Singapore

Singapore does not have a direct law that mentions Phishing. Under Section 3 of the Computer Misuse Act (CMA), Chapter 50 A and changes to Cybercrime laws can however deal with the matter of Phishing indirectly. A person involved in such an act would be liable to imprisonment up to 2 years or a monetary penalty of USD 5,000 would be imposed ([Global Legal Group, 2022f](#)).

7.12. Saudi Arabia

According to articles 1–4 of Anti crime cyber law (ACCL), a person involved in Phishing would be liable to imprisonment up to 3 years, and/or a monetary penalty not exceeding SAR 2,000,000 would be imposed ([Global Legal Group, 2022h](#)).

7.13. Portugal

Article 221 of the Portuguese Criminal Code says that anyone who messes with the outcome of data processing, structures computer programs incorrectly, uses data incorrectly or incompletely, messes with the processing without permission, or messes with the processing in any other way with the intention of getting illegally rich for themselves or for a third party can be fined or sent to prison for up to three years. Similarly, according to Article 6 of the Cybercrime Act, Phishing is also illegal because it is a type of unauthorized access. In this case, the Portuguese government has decided that anyone who accesses a computer system without the legal permission or authorization of the owner or holder of the right over the whole system or a part of it faces up to a year in prison (Global Legal Group, 2023).

7.14. China

China also does not have a direct law that talks about Phishing attacks though indirect laws to tackle fraud are there and apply during a Phishing scenario. In Article 253(1) (Global Legal Group, 2022a), the person involved with infringing a citizen's personal information is subject to 7 years of prison. Similarly, Article 287 deals with financial fraud.

7.15. European Union

European Union (EU) also does not directly deal with Phishing, but they do have indirect laws to tackle it. EU established European Cybercrime Centre (EC3) in 2013 through its law enforcement agency Europol, to deal with online crimes originating out of the EU, addressing citizens, businesses, and governments. EU in the year 2019 released a framework that allows them to impose sanctions on perpetrators involved in cyber crimes.

Discussion: In this section, we have discussed the legal aspects of Phishing attacks in different countries. As we have seen the laws are not adequate in many countries. In our view, it is not useful if some countries have stringent laws to prosecute the attackers since they can launch attacks from different countries. There is a need for cooperation between different countries or the introduction of international laws that can prosecute attackers across borders. However, it is still challenging to prosecute the attackers since the attackers often use compromised machines for conducting the attacks, and the owners of the compromised machines are not even aware that about the compromise of their machines. Furthermore, the laws are only helpful when government agencies are not involved in launching Phishing attacks and if there are enough cyber warriors.

8. Conclusions

In this paper, we have performed a comprehensive survey on Anti-Phishing aspects. We have classified and analyzed various deceptive Phishing redirection schemes as well as the schemes that are used to steal confidential/sensitive data through Phishing. The proposed paper has considered the following factors involving Phishing that are often ignored or are missing in other similar articles:

1. We have focused on classifying Phishing attacks more systematically. For this, we have focused on technical and non-technical factors involving Phishing. In particular, we focused on analyzing the role of social and cognitive factors in a successful Phishing attack. Social factors play an important role, and a deeper understanding of this area may be a new direction for anti-Phishing research.
2. We have also analyzed and classified different kinds of Phishers that target a victim individuals/organization and the motives that one can have while launching Phishing attacks. This classification is necessary to explore the reason behind launching a Phishing attack by a Phisher.
3. The paper also provides a classification of Phishing attacks based on the type of victim. This classification helps to understand the intended audience behind successful Phishing attacks and tells us how specific individuals/organizations are prone to certain Phishing attacks.
4. We have focused on the anti-Phishing organizations and solutions they offer to make the reader understand the overall scope of work that various organizations are doing in cyberspace to curb Phishing attacks. Many organizations are currently working on providing different Phishing detection and prevention mechanisms that include trend reports, anti-Phishing tool kits, anti-Phishing training and awareness, and simulation exercises. We believe that businesses must adopt such solutions provided by these organizations to counter Phishing attacks. Moreover, the employees in these businesses should be provided with anti-Phishing training and awareness to reduce employee susceptibility to Phishing.
5. To have the reader understand the techniques for Phishing detection and prevention, we have classified and discussed the major Phishing detection and prevention schemes that have been in place and proposed by researchers in the past.
6. A thorough knowledge of the different anti-Phishing laws in various countries is discussed and the famous case studies in the area of Phishing are discussed for a deeper understanding. Many countries have developed new anti-Phishing laws to counter Phishing attacks. This is the right step in the future, but still, there is a lot to be done.

In summary, Phishing has a large attack surface, and the attackers are successful in Phishing skilled IT professionals working in organizations such as Google, Microsoft, and Facebook. So it is a trivial task for attackers to perform Phishing attacks on unskilled IT professionals. Our analysis confirms that Phishing attacks are becoming more sophisticated as Phishing websites are hosted on HTTPS, and mobile devices Phishing has opened a whole new world for Phishers. Furthermore, technologies such as IoT and Big Data can make the attacks more worst in the near future. The possibility of more personalized automation with the IoT and the lack of security on IoT devices opens the door for attackers to use personalized information for generating attacks. We have also highlighted the significant gap in the knowledge for developing robust solutions against the attack, lack of cyber security awareness among the public, and inadequate laws in different countries make it difficult to deal with the problem effectively. We also identified the need for review and further research in real-time Phishing attack mitigation that can respond to and limit the damages that can be done via a Phishing attack campaign via real-time information sharing across various stakeholders. We want to study some of these areas in detail and convey our understanding in our future research works.

Overall the paper provides a new and comprehensive understanding of Phishing to people belonging to both Academia and Industry.

CRedit authorship contribution statement

Gaurav Varshney: Conceptualization, Methodology, Writing – original draft, Supervision, Resources. **Rahul Kumawat:** Writing – review & editing, Resources, Visualization. **Vijay Varadharajan:** Methodology, Supervision, Writing – review & editing. **Uday Tupakula:** Methodology, Supervision, Writing – review & editing. **Chandranshu Gupta:** Visualization, Writing – review & editing.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Data availability

No data was used for the research described in the article.

Acknowledgments

The authors would like to thank Mr. Gurwinder Atwal for his contributions to the paper. Mr. Atwal helped the authors in gaining an understanding of laws for Anti Phishing in various countries.

References

- Abdelhamid, N. (2015). Multi-label rules for phishing classification. *Applied Computing and Informatics*, 11(1), 29–46.
- Abdelhamid, N., Ayeshe, A., & Thabtah, F. (2014). Phishing detection based associative classification data mining. *Expert Systems with Applications*, 41(13), 5948–5959.
- Abroshan, H., Devos, J., Poels, G., & Laermans, E. (2021). A phishing mitigation solution using human behaviour and emotions that influence the success of phishing attacks. In *Adjunct proceedings of the 29th ACM conference on user modeling, adaptation and personalization* (pp. 345–350).
- Aburrous, M., Hossain, M. A., Dahal, K., & Thabtah, F. (2010). Intelligent phishing detection system for e-banking using fuzzy data mining. *Expert Systems with Applications*, 37(12), 7913–7921.
- Al-Ahmadi, S., Alotaibi, A., & Alsaleh, O. (2022). PDGAN: Phishing detection with generative adversarial networks. *IEEE Access*, 10, 42459–42468.
- Alabdan, R. (2020). Phishing attacks survey: Types, vectors, and technical approaches. *Future Internet*, 12.
- Alamri, E. K., Alnajim, A. M., & Alsubhany, S. A. (2022). Investigation of using CAPTCHA keystroke dynamics to enhance the prevention of phishing attacks. *Future Internet*, 14(3), 82.
- Alani, M. M., & Tawfik, H. (2022). PhishNot: A cloud-based machine-learning approach to phishing URL detection. *Computer Networks*, 218, Article 109407.
- Alhagail, A., & Alsabih, A. (2021). Applying machine learning and natural language processing to detect phishing email. *Computers & Security*, 110, Article 102414.
- Anandpara, V., Dingman, A., Jakobsson, M., Liu, D., & Roinestad, H. (2007). Phishing IQ tests measure fear, not ability. In *International conference on financial cryptography and data security* (pp. 362–366). Springer.
- APWG (2022). APWG | Phishing activity trends reports. URL: <https://apwg.org/trendsreports/>. (Accessed on 13 February 2022).
- Aravena, L. T., Bustos-Jiménez, J., & Casas, P. (2022). PHISHWEB: a progressive, multi-layered system for phishing websites detection. In *Proceedings of the 22nd ACM internet measurement conference* (pp. 764–765).
- Armano, G., Marchal, S., & Asokan, N. (2016). Real-time client-side phishing prevention add-on. *International Conference on Distributed Computing Systems*, <http://dx.doi.org/10.1109/icdcs.2016.44>.
- Australian Capital Territory (2002). Criminal code 2002. URL: <https://www.legislation.act.gov.au/DownloadFile/a/2002-51/current/PDF/2002-51.PDF>. (Accessed on 21 October 2019).
- Avanan (2019). *How Email became the weakest link, and what can be done about it?*. Avanan, URL: <https://www.avanan.com/how-email-became-the-weakest-link>. (Accessed on 21 October 2019).
- AVANAN (2019). Avanan | 2019 global phish report. URL: <https://www.avanan.com/global-phish-report>. (Accessed on 21 October 2019).
- AzarASK (2019). A new type of phishing attack. URL: <http://www.azarask.in/blog/post/a-new-type-of-phishing-attack/>. (Accessed on 21 October 2019).
- Azeez, N. A., Misra, S., Margaret, I. A., Fernandez-Sanz, L., & Abdulhamid, S. M. (2021). Adopting automated whitelist approach for detecting phishing attacks. *Computers & Security*, 108, Article 102328.
- Baker, I. (2019). SAASPAAS makes two factor authentication available to the masses. URL: <https://betanews.com/2015/01/15/saaspass-makes-two-factor-authentication-available-to-the-masses/>. (Accessed on 21 October 2019).
- Bankvault (2011). RSA SecurID attack. URL: <https://www.bankvault.com/classics-the-2011-rsa-hack/>. (Accessed on 31 March 2022).
- Bannister, A. (2021). bZx crypto heist results in reported losses of more than \$55 million. URL: <https://portswigger.net/daily-swig/bzx-crypto-heist-results-in-reported-losses-of-more-than-55-million>. (Accessed on 31 March 2022).
- Barracuda (2019). *Fight phishing attacks with email security awareness computer-based training*. Barracuda, URL: <https://www.barracuda.com/products/phishline>. (Accessed on 21 October 2019).
- Basit, A., Zafar, M., Liu, X., Javed, A. R., Jalil, Z., & Kifayat, K. (2021). A comprehensive survey of AI-enabled phishing attacks detection techniques. *Telecommunication Systems*, 76(1), 139–154.
- Bin, S., Qiaoyan, W., & Xiaoying, L. (2010). A DNS based anti-phishing approach. In *2010 Second international conference on networks security, wireless communications and trusted computing*, vol. 2 (pp. 262–265). IEEE.
- Bo, H., Wei, W., Liming, W., Guanggang, G., Yali, X., Xiaodong, L., & Wei, M. (2011). A hybrid system to find & fight phishing attacks actively. In *Proceedings of the 2011 IEEE/WIC/ACM international conferences on web intelligence and intelligent agent technology-volume 01* (pp. 506–509). IEEE Computer Society.
- Bonneau, J., Herley, C., Van Oorschot, P. C., & Stajano, F. (2012). The quest to replace passwords: A framework for comparative evaluation of web authentication schemes. In *2012 IEEE symposium on security and privacy* (pp. 553–567). IEEE.
- Cabarrus County (2019). *News release*. Government of Cabarrus County, URL: <https://www.cabarruscounty.us/news/cabarrus-county-government-targeted-in-social-engineering-scam>. (Accessed on 21 October 2019).
- Caputo, D. D., Pfeeger, S. L., Freeman, J. D., & Johnson, M. E. (2013). Going spear phishing: Exploring embedded training and awareness. *IEEE Security & Privacy*, 12(1), 28–38.
- Chang, E. H., Chiew, K. L., Sze, S. N., & Tiong, W. K. (2013). Phishing detection via identification of website identity. In *2013 international conference on IT convergence and security* (pp. 1–4). IEEE.
- Chen, T.-C., Stepan, T., Dick, S., & Miller, J. (2014). An anti-phishing system employing diffused information. *ACM Transactions on Information and System Security*, 16(4), 16.
- Chen, C. S., Su, S.-A., & Hung, Y.-C. (2011). Protecting computer users from online frauds. In *Google patents*, US patent 7,958,555.
- Chiew, K. L., Chang, E. H., Sze, S. N., & Tiong, W. K. (2015). Utilisation of website logo for phishing detection. *Computers & Security*, 54, 16–26.
- Chiew, K. L., Choo, J. S.-F., Sze, S. N., & Yong, K. S. (2018). Leverage website favicon to detect phishing websites. *Security and Communication Networks*, 2018.
- Cofense (2019). *Employee conditioning for resiliency against phishing*. Cofense, URL: <https://cofense.com/product-services/phishme/>. (Accessed on 21 October 2019).
- Cofense (2020). *Cofense Q3 2020 phishing review*. Cofense, URL: <https://go.cofense.com/q3-2020-phishing-review/>. (Accessed on 08 June 2023).
- Cofense (2023). Cofense: Stop email security threats and protect your company. URL: <https://cofense.com/>. (Accessed on 09 February 2023).
- Das, A., Baki, S., El Aassal, A., Verma, R., & Dunbar, A. (2020). SoK: A comprehensive reexamination of phishing research from the security perspective. *IEEE Communications Surveys & Tutorials*, 22(1), 671–708.
- De Ryck, P., Nikiforakis, N., Desmet, L., & Joosen, W. (2013). Tabshots: Client-side detection of tabnabbing attacks. In *Proceedings of the 8th ACM SIGSAC symposium on information, computer and communications security* (pp. 447–456). ACM.
- Desolda, G., Ferro, L. S., Marrella, A., Catarci, T., & Costabile, M. F. (2021). Human factors in phishing attacks: A systematic literature review. *ACM Computing Surveys*, 54(8), 1–35.
- DMARC (2021). *DMARC adoption statistics*. Domain-based Message Authentication, Reporting and Conformance, URL: <https://dmarc.org/2022/03/dmarc-policies-up-84-for-2021/>. (Accessed on 31 March 2022).
- Dodson, B., Sengupta, D., Boneh, D., & Lam, M. S. (2010). Secure, consumer-friendly web authentication and payments with a phone. In *International conference on mobile computing, applications, and services* (pp. 17–38). Springer.
- Dou, Z., Khalil, I., Khreishah, A., Al-Fuqaha, A., & Guizani, M. (2017). Systematization of knowledge (SoK): A systematic review of software-based web phishing detection. *IEEE Communications Surveys & Tutorials*, 19(4), 2797–2819.
- Downs, J. S., Holbrook, M., & Cranor, L. F. (2007). Behavioral response to phishing risk. In *Proceedings of the anti-phishing working groups 2nd annual ecrime researchers summit* (pp. 37–44).
- Dunlop, M., Groat, S., & Shelly, D. (2010). Goldphish: Using images for content-based phishing analysis. In *2010 Fifth international conference on internet monitoring and protection* (pp. 123–128). IEEE.
- Durumeric, Z., Adrian, D., Mirian, A., Kasten, J., Bursztein, E., Lidzborski, N., Thomas, K., Eranti, V., Bailey, M., & Halderman, J. A. (2015). Neither snow nor rain nor MITM... an empirical analysis of email delivery security. In *Proceedings of the 2015 internet measurement conference* (pp. 27–39).
- FBI (2009). *Operation phish phry*. FBI, URL: https://archives.fbi.gov/archives/news/stories/2009/october/phishphry_100709. (Accessed on 31 March 2022).
- Fortin, J. (2019). *He tried to bilk google and facebook out of \$100 million with fake invoices*. New York Times, URL: <https://www.nytimes.com/2019/03/25/business/facebook-google-wire-fraud.html>. (Accessed on 21 October 2019).
- Fortra's PhishLabs (2019). 2019 PTI report: The evolving threat. URL: <https://info.phishlabs.com/2019-pti-report-evolving-threat>. (Accessed on 21 October 2019).
- Foster, I. D., Larson, J., Masich, M., Snoeren, A. C., Savage, S., & Levchenko, K. (2015). Security by any other name: On the effectiveness of provider based email security. In *Proceedings of the 22nd ACM SIGSAC conference on computer and communications security* (pp. 450–464).

- Gastellier-Prevost, S., Granadillo, G. G., & Laurent, M. (2011). A dual approach to detect pharming attacks at the client-side. In *2011 4th IFIP international conference on new technologies, mobility and security* (pp. 1–5). IEEE.
- Global Legal Group (2022a). Cybersecurity laws and regulations report 2023 China. URL: <https://iclg.com/practice-areas/cybersecurity-laws-and-regulations/china>. (Accessed on 8 February 2023).
- Global Legal Group (2022b). Cybersecurity laws and regulations report 2023 France. URL: <https://iclg.com/practice-areas/cybersecurity-laws-and-regulations/france>. (Accessed on 8 February 2023).
- Global Legal Group (2022c). Cybersecurity laws and regulations report 2023 Germany. URL: <https://iclg.com/practice-areas/cybersecurity-laws-and-regulations/germany>. (Accessed on 8 February 2023).
- Global Legal Group (2022d). Cybersecurity laws and regulations report 2023 Italy. URL: <https://iclg.com/practice-areas/cybersecurity-laws-and-regulations/italy>. (Accessed on 8 February 2023).
- Global Legal Group (2022e). Cybersecurity laws and regulations report 2023 Japan. URL: <https://iclg.com/practice-areas/cybersecurity-laws-and-regulations/japan>. (Accessed on 8 February 2023).
- Global Legal Group (2022f). Cybersecurity laws and regulations report 2023 Singapore. URL: <https://iclg.com/practice-areas/cybersecurity-laws-and-regulations/singapore>. (Accessed on 8 February 2023).
- Global Legal Group (2022g). Cybersecurity laws and regulations report 2023 Switzerland. URL: <https://iclg.com/practice-areas/cybersecurity-laws-and-regulations/switzerland>. (Accessed on 8 February 2023).
- Global Legal Group (2022h). Data protection laws and regulations report 2022–2023 Saudi Arabia. URL: <https://iclg.com/practice-areas/data-protection-laws-and-regulations/saudi-arabia>. (Accessed on 8 February 2023).
- Global Legal Group (2023). Cybersecurity laws and regulations report 2023 Portugal. URL: <https://iclg.com/practice-areas/cybersecurity-laws-and-regulations/portugal>. (Accessed on 27 March 2023).
- Google (2019a). *Stronger security for your google account*. Google, URL: <https://www.google.com/landing/2step/>. (Accessed on 21 October 2019).
- Google (2019b). *Use a security key for 2 step verification*. Google, URL: <https://support.google.com/accounts/answer/6103523>. (Accessed on 21 October 2019).
- Government of Australia (2019a). *Crimes act 1900*. Government of Australia, URL: http://www8.austlii.edu.au/cgi-bin/viewdb/au/legis/nsw/consol_act/ca190082/. (Accessed on 21 October 2019).
- Government of Australia (2019b). *Crimes act 1958*. Government of Australia, URL: http://www.legislation.vic.gov.au/Domino/Web_Notes/LDMS/LTObject_Store/LTObjSt6.nsf/b1612aeaf0625227ca257619000d0882/a57e26dfdb404dcca257975000569fb/%24FILE/58-6231aa229A%20authorised.pdf. (Accessed on 21 October 2019).
- Government of Australia (2019c). *Criminal code act 1924*. URL: <https://www.legislation.tas.gov.au/view/html/inforce/current/act-1924-069>. (Accessed on 21 October 2019).
- Government of Australia (2019d). *Criminal law consolidation act 1935*. Government of Australia, URL: <https://www.legislation.sa.gov.au/LZ/C/A/CRIMINAL%20LAW%20CONSOLIDATION%20ACT%201935/CURRENT/1935.2252.AUTH.PDF>. (Accessed on 21 October 2019).
- Government of India (2008). *The information technology ACT, 2008*. Government of India, URL: [https://police.py.gov.in/Information%20Technology%20Act%202000%20-%202008%20\(amendment\).pdf](https://police.py.gov.in/Information%20Technology%20Act%202000%20-%202008%20(amendment).pdf). (Accessed on 09 February 2023).
- Government of U. K. (2006). *Fraud act 2006*. Government of UK, URL: http://www.legislation.gov.uk/ukpga/2006/35/pdfs/ukpga_20060035_en.pdf. (Accessed on 21 October 2019).
- Government of USA (2002). *Sarbanes-oxley act of 2002*. Government of USA, URL: <https://legcounsel.house.gov/Comps/Sarbanes-oxley%20Act%200f%202002.pdf>. (Accessed on 21 October 2019).
- Group-IB (2019). *Silence 2.0*. Group-IB, URL: https://www.group-ib.com/resources/threat-research/silence_2.0.going_global.pdf. (Accessed on 21 October 2019).
- Haynes, K., Shirazi, H., & Ray, I. (2021). Lightweight URL-based phishing detection using natural language processing transformers for mobile devices. *Procedia Computer Science*, 191, 127–134.
- He, M., Horng, S.-J., Fan, P., Khan, M. K., Run, R.-S., Lai, J.-L., Chen, R.-J., & Sutanto, A. (2011). An efficient phishing webpage detector. *Expert Systems with Applications*, 38(10), 12018–12027.
- Health & Human Services (2005). *Summary of the hipaa privacy rule*. United States Department of Health and Human Services, URL: <https://www.hhs.gov/sites/default/files/privacysummary.pdf>. (Accessed on 21 October 2019).
- Homayoun, S., Hageman, K., Afzal-Houshmand, S., Jensen, C. D., & Pedersen, J. M. (2022). Detecting ambiguous phishing certificates using machine learning. In *2022 International conference on information networking* (pp. 1–6). IEEE.
- Hu, H., & Wang, G. (2018). Revisiting email spoofing attacks. <http://dx.doi.org/10.48550/ARXIV.1801.00853>, URL: <https://arxiv.org/abs/1801.00853>.
- Huh, J. H., & Kim, H. (2011). Phishing detection with popular search engines: Simple and effective. In *International symposium on foundations and practice of security* (pp. 194–207). Springer.
- Indrasiri, P. L., Halgamuge, M. N., & Mohammad, A. (2021). Robust ensemble machine learning model for filtering phishing URLs: Expandable random gradient stacked voting classifier (ERG-SVC). *IEEE Access*, 9, 150142–150161.
- IronScales (2019a). *IronSchool: Attack simulation and attack awareness training*. URL: <https://ironscales.com/security-awareness-training-ironschool/>. (Accessed on 21 October 2019).
- IronScales (2019b). IronScales: Rapid automated phishing response platform. URL: <https://ironscales.com>. (Accessed on 21 October 2019).
- Jain, A. K., & Gupta, B. (2018a). PHISH-SAFE: URL features-based phishing detection system using machine learning. In *Cyber security* (pp. 467–474). Springer.
- Jain, A. K., & Gupta, B. B. (2018b). Two-level authentication approach to protect from phishing attacks in real time. *Journal of Ambient Intelligence and Humanized Computing*, 9(6), 1783–1796.
- Jansen, J., & van Schaik, P. (2019). The design and evaluation of a theory-based intervention to promote security behaviour against phishing. *International Journal of Human-Computer Studies*, 123, 40–55.
- Jindal, S., & Misra, M. (2021). Multi-factor authentication scheme using mobile app and camera. In *Advances in communication and computational technology* (pp. 787–813). Springer.
- Kambourakis, G., Gil, G. D., & Sanchez, I. (2020). What email servers can tell to Johnny: an empirical study of provider-to-provider email security. *IEEE Access*, 8, 130066–130081.
- Kaspersky (2019). *Spam and phishing reports*. Kaspersky, URL: <https://securelist.com/all/?category=918>. (Accessed on 21 October 2019).
- Kaspersky (2022). *Spam and phishing reports*. Kaspersky, URL: <https://securelist.com/spam-phishing-scam-report-2022/108692/>. (Accessed on 09 June 2023).
- Kausar, F., Al-Otaibi, B., Al-Qadi, A., & Al-Dossari, N. (2014). Hybrid client side phishing websites detection approach. *International Journal of Advanced Computer Science and Applications (IJACSA)*, 5(7), 132–140.
- Khonji, M., Iraqi, Y., & Jones, A. (2013). Phishing detection: A literature survey. *IEEE Communications Surveys & Tutorials*, 15(4), 2091–2121.
- Kim, S.-H., Choi, D., Jin, S.-H., & Lee, S.-H. (2013). Geo-location based QR-code authentication scheme to defeat active real-time phishing attack. In *Proceedings of the 2013 ACM workshop on digital identity management* (pp. 51–62). ACM.
- KnowBe4 (2019a). *Kevin mitnick security awareness training*. KnowBe4, URL: <https://www.knowbe4.com/products/kevin-mitnick-security-awareness-training/>. (Accessed on 21 October 2019).
- KnowBe4 (2019b). KnowBe4: Security awareness training. URL: <https://www.knowbe4.com>. (Accessed on 21 October 2019).
- Krishnamurthy, B., Spatscheck, O., Van Der Merwe, J., & Ramachandran, A. (2014). Method and apparatus for identifying phishing websites in network traffic using generated regular expressions. In *Google patents, US patent 8,776,224*.
- Lam, I.-F., Xiao, W.-C., Wang, S.-C., & Chen, K.-T. (2009). Counteracting phishing page polymorphism: An image layout analysis approach. In *International conference on information security and assurance* (pp. 270–279). Springer.
- Leung, C.-M. (2009). Depriving phishing by CAPTCHA with OTP. In *2009 3rd international conference on anti-counterfeiting, security, and identification in communication* (pp. 187–192). IEEE.
- Li, L., Berki, E., Helenius, M., & Ovaska, S. (2014). Towards a contingency approach with whitelist and blacklist-based anti-phishing applications: what do usability tests indicate? *Behaviour & Information Technology*, 33(11), 1136–1147.
- Lin, Y., Liu, R., Divakaran, D. M., Ng, J. Y., Chan, Q. Z., Lu, Y., Si, Y., Zhang, F., & Dong, J. S. (2021). Phishpedia: A hybrid deep learning based approach to visually identify phishing webpages. In *30th USENIX security symposium* (pp. 3793–3810).
- Liu, D.-J., Geng, G.-G., & Zhang, X.-C. (2022). Multi-scale semantic deep fusion models for phishing website detection. *Expert Systems with Applications*, 209, Article 118305.
- Liu, R., Lin, Y., Yang, X., Ng, S. H., Divakaran, D. M., & Dong, J. S. (2022). Inferring phishing intention via webpage appearance and dynamics: A deep vision based approach. In *31st USENIX security symposium* (pp. 1633–1650).
- Lookout (2018). *Mobile phishing 2018: Myths and facts facing every modern enterprise today*. Lookout, URL: <https://info.lookout.com/rs/051-ESQ-475/images/Lookout-Phishing-wp-us.pdf>. (Accessed on 21 October 2019).
- Lu, Y., Li, L., Peng, H., & Yang, Y. (2017). A novel smart card based user authentication and key agreement scheme for heterogeneous wireless sensor networks. *Wireless Personal Communications*, 96(1), 813–832.
- Ma, J., Saul, L. K., Savage, S., & Voelker, G. M. (2009). Beyond blacklists: learning to detect malicious web sites from suspicious URLs. In *Proceedings of the 15th ACM SIGKDD international conference on knowledge discovery and data mining* (pp. 1245–1254). ACM.
- Mao, J., Li, P., Li, K., Wei, T., & Liang, Z. (2013). BaitAlarm: detecting phishing sites using similarity in fundamental visual features. In *2013 5th international conference on intelligent networking and collaborative systems* (pp. 790–795). IEEE.
- MediaPro (2019a). *Security awareness training*. MediaPro, URL: <https://www.mediapro.com/security-awareness-trainingpack/>. (Accessed on 21 October 2019).
- MediaPro (2019b). MediaPRO digital security awareness training. URL: <https://www.mediapro.com>. (Accessed on 21 October 2019).
- Moghimi, M., & Varjani, A. Y. (2016). New rule-based phishing detection method. *Expert Systems with Applications*, 53, 231–242.
- Mohammad, R., McCluskey, T., & Thabtah, F. A. (2013). Predicting phishing websites using neural network trained with back-propagation. In *Proceedings of the 2013 world congress in computer science, computer engineering, and applied computing* (pp. 682–686). World Congress in Computer Science, Computer Engineering, and Applied Computing.

- Mohammad, R. M., Thabtah, F., & McCluskey, L. (2014a). Intelligent rule-based phishing websites classification. *IET Information Security*, 8(3), 153–160.
- Mohammad, R. M., Thabtah, F., & McCluskey, L. (2014b). Predicting phishing websites based on self-structuring neural network. *Neural Computing and Applications*, 25(2), 443–458.
- Mohammad, R. M., Thabtah, F., & McCluskey, L. (2015). Tutorial and critical analysis of phishing websites methods. *Computer Science Review*, 17, 1–24.
- Mukhopadhyay, S., & Argles, D. (2011). An Anti-Phishing mechanism for single sign-on based on QR-code. In *International conference on information society* (pp. 505–508). IEEE.
- Nagalingam, V., Narayana Samy, G., Ahmad, R., Maarop, N., & Ibrahim, R. (2015). Identifying the level of user awareness and factors on phishing attempt among students. *Advanced Science Letters*, 21(10), 3243–3247.
- Nguyen, L. A. T., To, B. L., Nguyen, H. K., & Nguyen, M. H. (2014). A novel approach for phishing detection using URL-based heuristic. In *2014 International conference on computing, management and telecommunications* (pp. 298–303). IEEE.
- Oregon (2019). *News release data breach*. Oregon Department of Human Services, URL: <https://www.oregon.gov/DHS/DHSNEWS/NewsReleases/Data-Breach-News%20Release-2019-03-21.pdf>. (Accessed on 21 October 2019).
- P. C. I. Security Standards Council (2019). *PCI DSS quick reference guide*. PCI Security Standards Council, URL: <https://www.pcisecuritystandards.org/documents/PCI%20SSC%20Quick%20Reference%20Guide.pdf>. (Accessed on 21 October 2019).
- Pearson, E., Bethel, C. L., Jarosz, A. F., & Berman, M. E. (2017). “To click or not to click is the question”: Fraudulent URL identification accuracy in a community sample. In *2017 IEEE international conference on systems, man, and cybernetics* (pp. 659–664). IEEE.
- PhishingBox (2019). *Phishing email IQ test*. PHISHINGBOX, URL: <https://www.phishingbox.com/phishing-iq-test>. (Accessed on 21 October 2019).
- PhishLabs (2019a). *Security awareness training*. PHISHLABS, URL: <https://www.phishlabs.com/security-awareness-training/>. (Accessed on 21 October 2019).
- PhishLabs (2019b). PhishLabs: Digital risk protection. URL: <https://www.phishlabs.com/>. (Accessed on 21 October 2019).
- PhishLine (2019). PhishLine security awareness training. URL: <https://phishline.com/>. (Accessed on 21 October 2019).
- PhishMe (2017). *2017 Global phish report*. PhishMe Inc., URL: <https://cofense.com/wp-content/uploads/2017/11/Enterprise-Phishing-Resiliency-and-Defense-Report-2017.pdf>. (Accessed on 21 October 2019).
- PhishTank (2019). *PhishTank: Data about phishing on the Internet*. Phishtank, URL: <https://www.phishtank.com>. (Accessed on 21 October 2019).
- Ponemon Institute LLC. (2015). *The cost of phishing & value of employee training 2015*. Ponemon Institute LLC., URL: https://ualr.edu/itservices/files/2016/10/Ponemon_Institute_Cost_of_Phishing.pdf. (Accessed on 21 October 2019).
- ProofPoint (2019). *Try our phishing awareness training*. ProofPoint, URL: <https://www.proofpoint.com/us/learn-more/try-phishing-awareness-training>. (Accessed on 21 October 2019).
- Quah, J. S., & Sriganesh, M. (2008). Real-time credit card fraud detection using computational intelligence. *Expert Systems with Applications*, 35(4), 1721–1732. <http://dx.doi.org/10.1016/j.eswa.2007.08.093>.
- Ramesh, G., Krishnamurthi, I., & Kumar, K. S. S. (2014). An efficacious method for detecting phishing webpages through target domain identification. *Decision Support Systems*, 61, 12–22.
- Ramzan, Z. (2010). Phishing attacks and countermeasures. *Handbook of Information and Communication Security*, 433–448.
- Rao, R. S., & Pais, A. R. (2019). Jail-Phish: An improved search engine based phishing detection system. *Computers & Security*, 83, 246–267.
- Rao, R. S., Umarekar, A., & Pais, A. R. (2022). Application of word embedding and machine learning in detecting phishing websites. *Telecommunication Systems*, 79(1), 33–45.
- Saan, L. (2022). Australian internet statistics 2022. URL: <https://www.redsearch.com.au/resources/australian-internet-statistics/>.
- SAASPAAS (2019). *Two-factor authentication with proximity uses ibeacon bluetooth low energy (BLE) to authenticate users instantly*. SAASPAAS, URL: <https://saaspass.com/technologies/proximity-instant-login-two-factor-authentication-beacon/>. (Accessed on 21 October 2019).
- Sahingoz, O. K., Buber, E., Demir, O., & Diri, B. (2019). Machine learning based phishing detection from URLs. *Expert Systems with Applications*, 117, 345–357.
- Sanghavi, P., Kunchapu, A., Kulkarni, A., Solani, D., & Anson, A. (2022). Novel approach to phishing detection using ML and visual similarity. In J. I.-Z. Chen, H. Wang, K.-L. Du, & V. Suma (Eds.), *Machine learning and autonomous systems* (pp. 117–131). Singapore: Springer Nature Singapore.
- Sarika, S., & Paul, V. (2014). An anti-phishing framework to defend Tabnabbing attack. In *International conference on security and authentication* (pp. 132–135).
- Security (2022). Incident report: Employee and customer account compromise. URL: <https://www.twilio.com/blog/august-2022-social-engineering-attack>.
- Shahriar, H., & Zulkernine, M. (2012). Trustworthiness testing of phishing websites: A behavior model-based approach. *Future Generation Computer Systems*, 28(8), 1258–1271.
- Silva, C. M. R. d., Feitosa, E. L., & Garcia, V. C. (2020). Heuristic-based strategy for phishing prediction: A survey of URL-based approach. *Computers & Security*, 88, <http://dx.doi.org/10.1016/j.cose.2019.101613>.
- Singh, P., Maravi, Y. P., & Sharma, S. (2015). Phishing websites detection through supervised learning networks. In *2015 International conference on computing and communications technologies* (pp. 61–65). IEEE.
- Singh, A., & Tripathy, S. (2014). TabSol: an efficient framework to defend tabnabbing. In *2014 International conference on information technology* (pp. 173–178). IEEE.
- Soares, E. (2021). Brazil: Punishment for Crimes Committed Electronically or Over Internet Increased. URL: <https://www.loc.gov/item/global-legal-monitor/2021-06-08/brazil-punishment-for-crimes-committed-electronically-or-over-internet-increased/>. (Accessed on 8 February 2023).
- Source of Asia (2022). Vietnam's digital transformation outlook 2022. URL: <https://www.sourceofasia.com/vietnams-digital-transformation-outlook-2022/>.
- Symantec (2019). *Internet security threat report*. Symantec, URL: <https://docs.broadcom.com/doc/istr-24-2019-en>. (Accessed on 08 June 2023).
- Tang, L., & Mahmoud, Q. H. (2021). A survey of machine learning-based solutions for phishing website detection. *Machine Learning and Knowledge Extraction*, 3, 672–694.
- Tatang, D., Zettl, F., & Holz, T. (2021). The evolution of DNS-based email authentication: Measuring adoption and finding flaws. In *Proceedings of the 24th international symposium on research in attacks, intrusions and defenses* (pp. 354–369). RAID '21.
- Thennakoon, A., Bhagyan, C., Premadasa, S., Mihiranga, S., & Kuruwitaarachchi, N. (2019). Real-time credit card fraud detection using machine learning. *International Conference on Cloud Computing*, <http://dx.doi.org/10.1109/confluence.2019.8776942>.
- TrendMicro (2016). Russian banks spear phishing. URL: <https://www.trendmicro.com/vinfo/us/security/news/cybercrime-and-digital-threats/cybercriminal-gang-used-spear-phishing-to-steal-25m-russian-banks>. (Accessed on 31 March 2022).
- TrendMicro (2019a). *What is spear phishing?*. Trend Micro, URL: <https://success.trendmicro.com/solution/1121072-what-is-spear-phishing>. (Accessed on 21 October 2019).
- TrendMicro (2019b). Unatrak holding limited BEC scam. URL: <https://www.trendmicro.com/vinfo/us/security/news/cybercrime-and-digital-threats/bec-scam-costing-almost-us-11-million-leads-to-fbi-arrest-of-nigerian-businessman>. (Accessed on 31 March 2022).
- Unlu, S. A., & Bicakci, K. (2010). Notabnab: Protection against the “tabnabbing attack”. In *2010 ECR research summit* (pp. 1–5). IEEE.
- Vade (2023). Vade releases 2022 phishers' favorites report. URL: <https://www.vadesecure.com/en/company/news/vade-releases-2022-phishers-favorites-report>.
- Varshney, G., Misra, M., & Atrey, P. K. (2016). A phishing detector using lightweight search features. *Computers & Security*, 62, 213–228.
- Vidyakeerthi, S., Nabeel, M., Elvitigala, C., & Keppityagama, C. (2022). PhishChain: A decentralized and transparent system to blacklist phishing URLs. In *Companion proceedings of the web conference 2022* (pp. 286–289).
- Wikipedia contributors (2020). 2020 Twitter account hijacking. URL: https://en.wikipedia.org/wiki/2020_Twitter_account_hijacking. (Accessed on 31 March 2022).
- Williams, E. J., Hinds, J., & Joinson, A. N. (2018). Exploring susceptibility to phishing in the workplace. *International Journal of Human-Computer Studies*, 120, 1–13.
- WombatSecurity (2019). Wombat security awareness and training software. URL: <https://www.wombatsecurity.com/>. (Accessed on 21 October 2019).
- World Bank Group (2022). GDP (current US\$) | Data. URL: <https://data.worldbank.org/indicator/NY.GDP.MKTP.CD>.
- Wu, L., Du, X., & Wu, J. (2014). MobiFish: A lightweight anti-phishing scheme for mobile phones. In *2014 23rd international conference on computer communication and networks* (pp. 1–8). IEEE.
- Xiang, G., & Hong, J. I. (2009). A hybrid phish detection approach by identity discovery and keywords retrieval. In *Proceedings of the 18th international conference on world wide web* (pp. 571–580). ACM.
- Xiang, G., Hong, J., Rose, C. P., & Cranor, L. (2011). Cantina+: A feature-rich machine learning framework for detecting phishing web sites. *ACM Transactions on Information and System Security*, 14(2), 21.
- Xie, M., Li, Y., Yoshigoe, K., Seker, R., & Bian, J. (2015). CamAuth: Securing web authentication with camera. In *2015 IEEE 16th international symposium on high assurance systems engineering* (pp. 232–239). IEEE.
- Xu, L., Zhan, Z., Xu, S., & Ye, K. (2013). Cross-layer detection of malicious websites. In *Proceedings of the Third ACM conference on data and application security and privacy* (pp. 141–152). ACM.
- Zhu, B. B., Yan, J., Bao, G., Yang, M., & Xu, N. (2014). CAPTCHA as graphical passwords—A new security primitive based on hard AI problems. *IEEE Transactions on Information Forensics and Security*, 9(6), 891–904.
- Zhuang, W., Jiang, Q., & Xiong, T. (2012). An intelligent anti-phishing strategy model for phishing website detection. In *2012 32nd international conference on distributed computing systems workshops* (pp. 51–56). IEEE.